CASE STUDY

Industrial Control System Attacks and Advisories, 2024 to 2026: Incidents, CVEs and Attribution

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

Between January 2024 and November 2026, people who run water plants, district heating, pipelines, dams and wind farms watched attacks on their controllers move from screen defacements to real physical effects. Heat went off in more than 600 apartment buildings in Ukraine in January 2024, in the Lviv area [5] [4] (**Confirmed** for the outage; **Reported** for the location detail). A dam valve in western Norway ran open for about four hours in April 2025 [14] (**Reported**). More than 30 Polish wind and solar farms lost contact with their grid operator on 29 December 2025 [20] (**Confirmed**). Water utilities in at least seven US states reported tampered PLCs and loss of pressure and flooding from 27 July 2026 [31] (**Confirmed**).

Over the same period, CISA published 1,389 ICS and medical-device advisories carrying more than 2,000 unique CVEs each year [37] (**Confirmed**, counted for this study). This study asks the question operators keep asking: how do the attacks and the CVE flood relate, and who is behind them? The short answer from the verified record (**Inferred**) is that the disruptive attacks rarely depended on the CVEs being announced; Part 3.2 sets out the four places where the two records meet. Nearly every disruptive event with a stated access path used no new vulnerability at all: default or missing passwords, internet-exposed HMIs and PLC programming ports, VNC, and the vendors' own engineering software [1] [12] [21] [29] [31] (**Confirmed** per event; the generalization is **Inferred**). Of 2,426 unique CVEs in the 2026 advisories, 21 are in CISA's Known Exploited Vulnerabilities (KEV) catalog, and 19 of those are IT components such as Linux, Chromium, Fortinet and PAN-OS embedded in OT products [37] [40] (**Confirmed**).

Attribution comes in layers. Governments name sponsors: Iran's IRGC Cyber-Electronic Command [2], Russia's GRU unit 74455 and the CISM center [12], Russia's FSB Center 16 [54], and the People's Republic of China [6] (**Confirmed** as each government states it). Vendors name clusters, and the clusters do not line up

one to one. Personas on Telegram claim credit and often exaggerate. The December 2025 Polish attack shows the gap plainly: the national CERT points to an FSB-linked infrastructure cluster, while ESET and Dragos point to Sandworm with medium or moderate confidence [21] [22] [23] (**Confirmed** that the sources disagree).

> Evidence grade: the incident facts, advisories and counts are **Confirmed** from government, vendor and victim primaries, except where only journalism was opened (**Reported**: Norway, Denmark, the Polish water attempt, Kansas, Minnesota, Asahi and the dwell time at a Massachusetts utility). Links between a KEV addition and a specific campaign are **Inferred** unless a source states them.

Key facts at a glance

Field	Value
Period	January 2024 to 3 November 2026, with the November 2023 Unitronics wave that set it up
CISA ICS advisories (ICSA and ICSMA)	422 with 2024 ids, 506 with 2025 ids, 461 with 2026 ids to 3 November [37]; the CISA listing shows 4,229 in total across all years [36]
Unique CVEs in those advisories	2,041 (2024), 2,302 (2025), 2,426 (2026, partial year) [37]
Share carried by Siemens advisories	70.0%, 59.2% and 50.9% of each year's unique CVEs, mostly third-party component bulletins [37]
KEV catalog	1,767 entries at catalogVersion 2026.11.03; 186 added in 2024, 245 in 2025, 283 in 2026 [40]
KEV entries citing a CISA ICS advisory	5 of the 714 added since 1 January 2024 [40]
2026 advisory CVEs that are in KEV	21 of 2,426; 19 are IT components inside OT products [37] [40]
NVD-to-KEV gap, 13 OT-product CVEs	Median 54 days; 4 within 30 days and 4 over a year; the longest is CVE-2021-22681 at 1,828 days [42]
Physical effects with a primary	Lviv heating outage (Jan 2024) [5]; Polish RTU damage (Dec 2025) [20]; PLC logic and alarm changes in US sectors (2026) [29]; US water loss of pressure and flooding (Jul 2026) [31]
Sponsors named by governments	IRGC-CEC [2]; GRU unit 74455 and CISM [12] [11]; FSB Center 16 [54]; PRC [6]
Key incident advisories that name a CVE	AA24-038A names one (CVE-2022-42475) [6]; AA25-343A, the AA26-097A web page and the July 2026 FBI/EPA PSA name none [12] [29] [31]
ATT&CK record bound here	43 ICS and 79 Enterprise techniques from advisories and ATT&CK pages, in two Navigator layers (Part 6)

Key findings

- **The disruptive events needed no new CVE.** The Unitronics wave used default or empty passwords on TCP 20256 [1]; the pro-Russia HMI intrusions used exposed VNC on ports 5900 to 5910 with default, weak or no passwords [12]; the 2026 Iranian-affiliated campaign reached exposed PLCs on 44818, 2222, 102 and 502 with the vendors' own programming software [29]; the Polish RTU firmware was uploaded through a web interface "Default" account [21] (**Confirmed**). The pattern across them is **Inferred**.
- **The CVE count measures supply chains more than attacks.** Three Siemens bulletins for Linux-based subsystems and third-party components carry 455, 486 and 428 CVEs each [37], and 19 of the 21 KEV CVEs in 2026 advisories are IT software such as the Linux kernel, Chromium, Fortinet, PAN-OS, ActiveMQ and MongoDB [37] [40] (**Confirmed**).
- **KEV reaches OT late and rarely.** Rockwell CVE-2021-22681 entered KEV on 5 March 2026, 1,828 days after NVD published it, a month before a joint advisory pointed Rockwell owners to its fix [42] [30] (**Confirmed**); that the KEV add was driven by the campaign is **Inferred**. ScadaBR CVE-2021-26828 was exploited on a Forescout honeypot in March 2025 and entered KEV in December 2025 [18] [40] (**Confirmed** for both dates; the causal link is **Inferred**).
- **Advisory text lags the exploitation signal.** A Lantronix advisory updated on 8 October 2026 still said no exploitation had been reported to CISA, although CVE-2025-67038 had been in KEV since 23 June 2026 [47] [40] (**Confirmed**). The "no known public exploitation" line appears in 253 of 461 advisories with 2026 ids [37].
- **Iranian-affiliated activity escalated from defacement to disruption.** In 2023 to 2024 the actors erased ladder logic and posted images [1] [2]; in 2026 they modified project logic, manipulated HMI and SCADA displays and disabled shutdown and alarm logic [29] (**Confirmed**). The 2026 advisory names no group and calls the 2023 CyberAv3ngers campaign only "similar" [29].
- **Russian state services use personas, and the personas overclaim.** The DOJ alleges the GRU founded, funded and directed CARR [11]; CISA and partners assess the GRU likely supported its creation and that CISM created NoName057(16) [12] (**Confirmed** as stated). Mandiant could not verify CARR's water and hydro claims [8], Claroty counted about 500 bricked Fuxnet gateways against 87,000 claimed sensors [61], and TwoNet claimed a honeypot as a real plant [18] (**Confirmed**).
- **Chinese activity is pre-positioning, not disruption.** Volt Typhoon held some victim IT footholds for at least five years and once moved laterally to a control system, with no OT disruption reported in AA24-038A [6] (**Confirmed**). Dragos says VOLTZITE reached its Stage 2 capability in 2025, with SYLVANITE handing it edge-device access [27] (**Confirmed** as Dragos's assessment).
- **The same event gets different names and different sponsors.** CERT Polska ties the December 2025 Polish infrastructure to the Static Tundra, Berserk Bear, Ghost Blizzard and Dragonfly cluster; ESET gives DynoWiper to Sandworm at medium confidence; Dragos gives the attack to ELECTRUM at moderate confidence [21] [22] [23] (**Confirmed**). ATT&CK C0063 records both readings [79].
- **The library lags the record.** Its ICS data lacks two techniques ATT&CK now lists for CyberAv3ngers, it has no pages for G1027, C0031, S1165, S1157 or S1045, and `THREAT_ACTORS.md` lists CyberAv3ngers with no ATT&CK id [82] [70] (**Confirmed**; fixes in Part 5.7).

Top recommendations

1. **Take PLCs, HMIs and programming ports off the internet, and find the cellular modems.** Reach controllers through a gateway or jump host; use a private APN or zero-trust access for modems [29]. CISA warned in July 2026 that undocumented cellular modems are part of the water-sector targeting [32].
2. **Change every default password and put phishing-resistant MFA on remote access.** Removing OT internet connections and changing default passwords are the first two fixes in CISA's primary OT mitigations [90], and EPA found unchanged default passwords and shared logins in its inspections of water systems [89].
3. **Protect the logic, not just the network.** Put Rockwell mode switches in RUN, turn on Siemens programming protection, compare running logic to known-good copies and check backups before restoring them [29].
4. **Rank ICS CVEs by exploitation and exposure, not by CVSS.** Use KEV and SSVC (Exploitation, Automatable, Technical Impact) with your own exposure data [48] [92] [93]. Treat the IT components inside OT products as IT patches on IT timelines.
5. **Do not wait for the advisory to say "exploited".** Watch KEV and vendor revisions directly: Siemens revised SSA-580366 to point at active exploitation four days after publishing it [44], while the Lantronix advisory still said no exploitation had been reported on 8 October 2026, more than three months after the KEV addition [47] [40].
6. **Watch for writes, not just scans.** Alert on PLC program, mode-change and Modbus write traffic from anything that is not an engineering workstation; Censys reports that even protocol-aware scanners on its honeypot stopped short of write or control operations, although its own example session shows a Modbus write request [86]. The rule design in Part 5.5 is **Inferred** and untested.
7. **Practise manual operation.** Kansas and Minnesota utilities fell back to manual operations [10] [33], and CISA lists the ability to operate manually as a primary mitigation [90].
8. **Read attribution as layers, act on behavior.** A sponsor named by a government, a vendor cluster and a Telegram persona are three different claims (Part 4). The defensive actions above do not depend on which one is right.

Scope and method

This study covers attacks on industrial control systems and operational technology from January 2024 to 3 November 2026, the ICS advisories and CVEs published in the same period, and the attribution record that links them. It reaches back to November 2023 for the Unitronics wave and, in Part 3.4, to 2017 to 2022 for the tools defenders compare these events to. It follows the method in the case studies README: primary sources first, every claim graded, numbers given as the source states them. Every source in the Sources table was opened on 3 November 2026. Direct quotations are kept under 15 words.

Counts of advisories, CVEs and CWEs are this study's own computation from CISA's CSAF repository (`cisagov/CSAF`, develop branch, commit `90e44dd` of 3 November 2026), not figures CISA publishes [37]. Advisories are bucketed by the year in their ICSA or ICSMA id (the folder year) and include the ICSMA medical advisories. Bucketing by `initial_release_date` instead gives different totals (2,224, 2,256 and 2,229 CVEs, with 20.8%, 16.2% and 15.4% older than two years), so the choice matters [37]. 2026 is a partial

year. KEV counts come from the feed at catalogVersion 2026.11.03 [40].

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: the government agency, the vendor or CERT that did the analysis, the victim's own statement, a data feed from the publisher, or the MITRE page itself
Reported	Stated only in journalism or in a secondary source relaying another party; the original was not opened
Demonstrated	A public reproduction exists that others can check (no claim in this study needed this grade)
Inferred	The study's own reasoning from Confirmed facts, labelled as such

Part 1: the incident record

1.1 Timeline

One row per dated incident, advisory or report. "None named" means the source opened names no actor.

Date	Event	What happened	Attribution as the source states it	Grade	Sources
2023-10 to 2024-01; again 2024-07 to 08	IOCONTROL on fuel systems	Embedded-Linux OT/IoT implant recovered from a Gasboy/Orpak fuel control system; targets routers, PLCs, HMIs and firewalls in Israel and the US; MQTT C2 on 8883; deployment method unclear	Team82: the system was "allegedly" compromised by CyberAv3ngers, believed to be part of IRGC-CEC	Confirmed	[3]
2023-11-22 to 2024-01	Unitronics PLC defacements	At least 75 US devices, at least 34 in water and wastewater, likely in four waves; default or no password on TCP 20256; ladder logic erased	IRGC-affiliated CyberAv3ngers (CISA and partners)	Confirmed	[1]
2023-12-05 and 2023-12-11	CVE-2023-6448 published and added to KEV	The VisiLogic default administrative password used in the wave got a CVE after the fact	n/a	Confirmed	[42]
2024-01-17 to 18	CARR videos on US and Polish water	Telegram videos claim HMI manipulation; officials at the affected US utilities later acknowledged incidents	Mandiant cannot verify the intrusions or their link to APT44	Confirmed (as claims)	[8]
2024-01	Texas tank overflows claimed	CARR claimed overflows of water storage tanks in Abernathy and Muleshoe, Texas	CARR, "Russian government-aligned" (Treasury)	Confirmed (as claims)	[67]
2024-01-22 to 23	FrostyGoop, Lviv	Heating outage for over 600 apartment buildings, about two days; Modbus TCP commands; MikroTik routers reportedly exploited	None named; ATT&CK C0041 and S1165 list no group	Confirmed (outage); Reported (MikroTik)	[5] [85] [4] [72]

Date	Event	What happened	Attribution as the source states it	Grade	Sources
2024-02-02	Treasury sanctions IRGC-CEC officials	Six officials sanctioned, including head Hamid Reza Lashgarian; the PLC operation did not disrupt critical services	IRGC-affiliated actors	Confirmed	[2]
2024-02-07	AA24-038A, Volt Typhoon	Pre-positioning on IT networks in communications, energy, transportation and water, in the US and Guam; footholds of at least five years in some victims; one lateral move to a control system; PuTTY profiles for water plants, wells and a substation	PRC state-sponsored, high confidence	Confirmed	[6]
2024-03-02	CARR video on a French hydro facility	Claimed disruption of generation by manipulating water levels	Not verified by Mandiant	Confirmed (as a claim)	[8]
2024-04 (Claroty 2024-04-12)	Fuxnet against Moscollector	Sensor gateways bricked; Claroty counted about 500 against a claimed 87,000 sensors; Blackjack later disputed the count	Blackjack, believed affiliated with Ukrainian intelligence (Claroty); a pro-Ukraine hacktivist group (Dragos)	Confirmed	[61] [5]
2024-04-17	Sandworm graduated to APT44	Mandiant names APT44, sponsored by Russian military intelligence	Mandiant	Confirmed	[9] [8]
2024-07	Joint CARR and NoName057(16) claim	An alleged intrusion against US OT assets	As claimed (AA25-343A)	Confirmed (as a claim)	[12]
2024-07-19	Treasury sanctions two CARR members	Leader and a primary hacker designated; SCADA compromise of a US energy company cited	CARR, Russian government-aligned	Confirmed	[67]
2024-09	Z-Pentest formed	Formed by CARR administrators unhappy with GRU support, with a NoName057(16) administrator	Separate from GRU involvement (AA25-343A)	Confirmed	[12]
2024-09-22	Arkansas City, Kansas	Water treatment facility switched to manual operations; water safe, no service disruption	None named; ransomware is press speculation	Reported	[10]
2024 (date not given)	Waterworks near Koege, Denmark	Pipes burst and homes were briefly without water (details from DR, as relayed by AP)	Z-Pentest, with links to the Russian state (DDIS, 2025-12-18, as relayed by AP)	Reported	[13]
2024-11	Los Angeles meat processing facility	Thousands of pounds of meat spoiled and an ammonia leak	CARR (DOJ indictment allegation)	Confirmed (as allegation)	[11]

Date	Event	What happened	Attribution as the source states it	Grade	Sources
2025-02-21 to 25	Forescout honeypot, Iranian IPs	Modbus coil writes and S7 tampering against PLC decoys	Source IPs in Iran	Confirmed	[18]
2025-02-25	Dragos 2025 Year in Review	23 groups tracked, 9 active in OT in 2024; new groups BAUXITE and GRAPHITE	BAUXITE overlaps the CyberAv3ngers persona; GRAPHITE overlaps APT28	Confirmed	[5]
2025-03-01 to 03	Forescout honeypot, HMI webshell	Default credentials, then CVE-2021-26828 to upload a Java webshell	Russian-linked IP addresses (Forescout's heading)	Confirmed	[18]
2025-03 to 07	KAMACITE reconnaissance	Reconnaissance of US industrial devices	Dragos	Confirmed	[26]
2025-04-07	Bremanger dam, Norway	Valve or flood gate opened; about 500 litres per second for four hours, over 7.2 million litres in total; no injuries	Pro-Russian cyber actors, no group named (PST, 2025-08-13); Kripos reached the same view in June	Reported	[14] [15]
2025-04 to 09	Sandworm wipers in Ukraine	ZEROLOT and Sting wipers against government, energy, logistics and the grain sector, likely to weaken the economy	Sandworm (ESET)	Confirmed	[25]
2025-05	Ukrainian ISPs	ELECTRUM attacked eight Ukrainian ISPs	Dragos	Confirmed	[26]
2025-06	Wipers during the Iran-Israel conflict	BAUXITE used two custom wiper variants against Israeli targets; PYROXENE deployed a wiper	Dragos	Confirmed	[26]
2025-06-30	Joint fact sheet on Iran	Iranian-affiliated actors may target US networks, especially defense firms tied to Israel; no coordinated Iranian campaign seen in the US	CISA, FBI, DC3 and NSA	Confirmed	[28]
2025	VOLTZITE and SYLVANITE	VOLTZITE reached US midstream pipeline operations through Sierra Wireless AirLink gateways; SYLVANITE exploited Ivanti at US electric and water utilities	Dragos; ATT&CK records SYLVANITE as a separate initial access cluster	Confirmed	[26] [78]
2025-08-13	Polish city water supply	An attack that could have cut a large city's water was detected and stopped	None named (Deputy PM Gawkowski)	Reported	[17]

Date	Event	What happened	Attribution as the source states it	Grade	Sources
2025-08-20	FBI PSA on FSB Center 16	Exploitation of CVE-2018-0171 in Cisco Smart Install on end-of-life devices; reconnaissance showed interest in ICS protocols	FSB Center 16 (also tracked as Berserk Bear, Dragonfly; Static Tundra per Cisco Talos)	Confirmed	[54]
2025-09	TwoNet on a Forescout decoy	Default credentials, HMI defacement via CVE-2021-26829, setpoint changes, alarms disabled, then a false claim of a real attack	TwoNet, pro-Russian (Forescout)	Confirmed	[18]
2025-09-02	Jaguar Land Rover	Systems shut down proactively; retail and production severely disrupted	None named in the statement	Confirmed	[34]
2025-09-29	Asahi	Production at Japanese factories halted, with orders, shipments and call centers	Not stated; ransomware not confirmed	Reported	[35]
2025-10-03	Bremanger case closed	Prosecutors dropped the case because no individuals were identified (iLaks citing NRK)	n/a	Reported	[16]
2025-10-29	Canada AL25-016	Hacktivists tampered with water pressure, an oil and gas tank gauge and a farm grain drying silo	Hacktivists, no group named	Confirmed	[19]
2025-11-28 and 2025-12-03	ScadaBR CVEs added to KEV	CVE-2021-26829 (XSS) and CVE-2021-26828 (file upload), about 4.5 years after NVD publication	KEV names no actor	Confirmed	[40] [42]
2025-12-09	AA25-343A and DOJ charges	Advisory on CARR, NoName057(16), Z-Pentest and Sector16; indictment; rewards of up to $2 million (CARR) and $10 million (NoName057(16))	GRU unit 74455 likely supported CARR; CISM created NoName057(16)	Confirmed	[12] [11]
2025-12-12	CVE-2018-4063 added to KEV	Sierra Wireless AirLink; the KEV entry cites ICSA-19-122-03	KEV names no actor	Confirmed	[40]
2025-12-29	Poland energy attack	More than 30 wind and PV farms, a manufacturer and a CHP plant with almost half a million heat customers; RTU damage cut DSO communications but production continued; EDR blocked the wiper at the CHP plant	Split: CERT Polska infrastructure overlap with the Static Tundra cluster; ESET Sandworm (medium); Dragos ELECTRUM (moderate)	Confirmed	[20] [21] [22] [23]

Date	Event	What happened	Attribution as the source states it	Grade	Sources
2026-01-14	NCSC secure connectivity principles	Eight principles for OT connectivity, written with seven partner agencies	NCSC-led	Confirmed	[91]
2026-02-17	Dragos 2026 Year in Review	26 groups, 11 active in 2025; new AZURITE, PYROXENE and SYLVANITE; 119 ransomware groups hit about 3,300 industrial organizations	Dragos	Confirmed	[26] [27]
2026-03-05	CVE-2021-22681 and CVE-2017-7921 added to KEV	Rockwell Logix key and Hikvision	KEV names no actor	Confirmed	[40] [42]
From at least 2026-03 (advisory 2026-04-07, updated 2026-07-22)	AA26-097A, Iranian-affiliated PLC campaign	Exposed Rockwell PLCs disrupted; Schneider and Siemens PLCs also targeted (July update); project files stolen, logic changed, displays manipulated, shutdown and alarm logic disabled; disruption and financial loss for some victims	Iranian-affiliated APT actors, no confidence level stated	Confirmed	[29] [30]
2026-06-10	BOD 26-04	Remediation urgency set by exposure, KEV status, automation and technical impact; revokes BOD 19-02 and 22-01	CISA	Confirmed	[93]
2026-06-23	CVE-2025-67038 added to KEV	Lantronix command injection; the advisory still said no exploitation on 2026-10-08	KEV names no actor	Confirmed	[40] [47]
2026-07-15	CVE-2023-4346 added to KEV	KNX; the entry cites ICSA-23-236-01	KEV names no actor	Confirmed	[40]
2026-07-26 to 27	Minnesota community water systems	Coordinated attack on OT at more than 30 systems; some switched to manual; no actor named as of 2026-07-31	None named	Reported	[33]
From 2026-07-27	US water MicroLogix incidents	Utilities in at least seven states; IP addresses and passwords changed on MicroLogix 1100 and 1400; loss of view and control, loss of pressure and flooding; modified project files at one victim	None named	Confirmed	[31]
2026-07-30	CISA water-sector alert	Significant increase in PLC targeting, including undocumented cellular modems; boil water notices and sustained manual operations	None named	Confirmed	[32]

Date	Event	What happened	Attribution as the source states it	Grade	Sources
2026-10-15 to 22	Siemens Software Center CVE-2026-110936	Published 10-15, revised 10-19 to reference active exploitation, KEV 10-20, republished by CISA as ICSA-26-295-03	KEV names no actor	Confirmed	[44] [40] [45]
2026-11-03	Newest CISA ICS advisory	ICSA-26-307-01, Subnet Solutions PowerSYSTEM Center	n/a	Confirmed	[36]

1.2 Iran: from defacement to logic changes

The Unitronics wave is where this period starts. CISA and partners describe IRGC-affiliated actors authenticating to internet-connected Unitronics Vision PLCs and HMIs on TCP 20256 where the password was the default or empty, erasing the ladder logic and leaving the message "You have been hacked, down with Israel" [1] (**Confirmed**). Treasury sanctioned six IRGC-CEC officials for those operations and noted that this operation did not disrupt any critical services [2] (**Confirmed**). Claroty's Team82 found a purpose-built implant, IOCONTROL, on a Gasboy fuel control system, tied it to the same persona and dated a relaunch to July and August 2024 [3] (**Confirmed**, with Team82's own "allegedly" kept).

The 2026 campaign is a step up. AA26-097A describes actors who reached exposed Rockwell CompactLogix and Micro850 controllers, and in its July update Schneider Modicon M340 and Siemens S7-1200 controllers and cellular modems, using Studio 5000, EcoStruxure Control Expert and TIA Portal from leased hosting, with Dropbear SSH on modems [29] (**Confirmed**; the Schneider, Siemens and Dropbear details date from the 2026-07-22 update). They modified and deleted project logic, including Add-On Instructions, manipulated HMI and SCADA displays and disabled shutdown and alarm logic [29] (**Confirmed**). The advisory links the escalation, with a "likely", to hostilities between Iran and the United States and Israel, and says it is not highlighting a new vulnerability [29] (**Confirmed**). Between those two points, Dragos reports BAUXITE using two wiper variants against Israel during the June 2025 conflict and a new group, PYROXENE, deploying a wiper [26] (**Confirmed**), while the joint June 2025 fact sheet said no coordinated Iranian campaign had yet been seen in the US [28] (**Confirmed**).

1.3 Russia: the GRU, its personas and the wipers

Mandiant graduated Sandworm to APT44 in April 2024 and describes it as sponsored by Russian military intelligence [9]; its report, citing government attributions, ties the group to GRU Unit 74455 (GTsST) [8] (**Confirmed**). In Ukraine the record is one of wipers: ZEROLOT and Sting against government, energy, logistics and grain targets from April to September 2025 [25], and ELECTRUM against eight ISPs in May 2025 [26] (**Confirmed**).

Outside Ukraine, the Russian-aligned activity reached Western utilities mostly through personas. CARR posted videos claiming HMI manipulation at US and Polish water utilities and a French hydro plant [8], claimed the Texas tank overflows [67], and, per the DOJ indictment, attacked US drinking water systems and a Los Angeles meat plant [11] (**Confirmed** as claims and allegations). AA25-343A describes the shared method: scan for VNC on 5900 to 5910, guess or skip the password, change HMI settings, and cause mostly loss of view [12] (**Confirmed**). Norway's PST blamed pro-Russian actors for the Bremanger dam without naming a group, Kripos had reached the same view from a Telegram video with a watermark associated with a

pro-Russian group, and the case closed without suspects [14] [15] [16] (**Reported**). Denmark's DDIS attributed the Koege waterworks attack to Z-Pentest [13] (**Reported**).

1.4 Poland, 29 December 2025

This is the most destructive event in the period and the clearest attribution dispute. CERT Polska's report describes coordinated attacks on more than 30 wind and photovoltaic farms, a manufacturer and a combined heat and power plant; damage to RTUs cut communication with the distribution operator, but energy production continued, and EDR blocked the wiper at the CHP plant [20] (**Confirmed**). The Hitachi RTUs that supported secure update did not have it enabled, and CVE-2024-2617 would have let an attacker bypass it anyway; the firmware was uploaded after logging in with the "Default" account [21] (**Confirmed**). LazyWiper, a PowerShell wiper used at the manufacturer [24], was likely written largely with a large language model, and CERT Polska says it cannot be used for attribution [21] (**Confirmed**). Part 4.5 sets out the three readings of who did it.

1.5 China: pre-positioning in IT, reaching toward OT

AA24-038A is a warning about intent, not a record of disruption. CISA, NSA and FBI assess with high confidence that PRC state-sponsored Volt Typhoon is pre-positioning on IT networks for disruptive attacks in a crisis, with initial access through Fortinet, Ivanti, NETGEAR, Citrix and Cisco appliances, theft of NTDS.dit, and tests of default OT vendor credentials on domain-joined OT assets [6] (**Confirmed**). The only CVE it names is CVE-2022-42475 on a FortiGate 300D [6]. At Littleton Electric Light and Water Departments in Massachusetts, Dragos told SecurityWeek the intrusion it attributes to VOLTZITE lasted from February to November 2023, more than 300 days, and aimed at OT operating procedures and spatial layout data [7] (**Reported**; the Dragos case study itself was not opened). Dragos's 2026 review adds VOLTZITE reaching midstream pipelines through Sierra Wireless AirLink gateways and dumping engineering workstation configuration and alarm data, SYLVANITE handing it edge-device access, and AZURITE (Flax Typhoon overlap) stealing OT data [26] [27] (**Confirmed** as Dragos's assessments).

1.6 Unattributed and hacktivist events

Several of the events with the clearest physical effect have no named actor. FrostyGoop cut heat in Lviv with ordinary Modbus TCP commands; Dragos assessed with moderate confidence that it can affect other Modbus TCP devices, and ATT&CK lists no group for it [4] [72] (**Reported** for the Dragos assessment, **Confirmed** for ATT&CK). The July 2026 MicroLogix incidents in US water, the 30-plus Minnesota systems, the Canadian water, oil and gas and grain-silo tampering, and the foiled Polish water attack all name no actor [31] [33] [19] [17]. The Forescout honeypot shows how cheap these intrusions are: default credentials, an old ScadaBR CVE, setpoint changes and a false claim on Telegram [18] (**Confirmed**).

1.7 Ransomware and the production line

Ransomware stopped production more often than state actors did. Dragos counts 119 ransomware groups hitting industrial organizations in 2025, up from 80 in 2024, about 3,300 organizations affected, manufacturing more than two-thirds of victims and an average OT dwell time of 42 days [26] (**Confirmed** as Dragos's count; its blog calls the rise in groups a 49 percent increase [27]). Jaguar Land Rover shut down its systems on 2 September 2025 and said retail and production were severely disrupted, with no attribution [34] (**Confirmed**). Asahi halted its Japanese factories after a "system failure" on 29 September 2025; ransomware was not confirmed in the source [35] (**Reported**).

Part 2: the advisory and CVE record

2.1 Volume

CISA defines ICSA advisories as covering novel vulnerabilities in ICS, OT and IoT products and ICSMA as covering medical devices [36] (**Confirmed**). In its CSAF repository there are 422 advisories with 2024 ids, 506 with 2025 ids and 461 with 2026 ids to 3 November (409, 482 and 443 if only ICSA files are counted) [37] (**Confirmed**). They carry 2,041, 2,302 and 2,426 unique CVEs, and the share of CVEs whose id year is two or more years before the advisory year rose from 16.4% and 16.9% to 21.2% [37] (**Confirmed**, computed).

Releases cluster on two days. In 2025, advisories went out on 94 distinct days, 294 of them on Thursdays and 185 on Tuesdays, taking the day from the advisory id [37] (**Confirmed**, computed). Siemens ProductCERT, by contrast, distributes through a CSAF feed, RSS and an email list, and its page states no schedule [98] (**Confirmed**).

2.2 Vendor concentration

Vendor	2024 ids	2025 ids	2026 ids
Siemens	150	133	103
Rockwell Automation	55	49	34
Schneider Electric	16	54	29
ABB	1	14	32
Hitachi Energy	11	31	24
Mitsubishi Electric	17	17	11
Delta Electronics	14	15	6
Honeywell	1	2	2
Moxa	1	0	1
Phoenix Contact	0	0	0

Source: [37], vendor taken from the CSAF product tree by case-insensitive match (Mitsubishi includes Iconics; Rockwell's 2025 count includes one variant vendor string). The ten vendors above account for 63.0%, 62.3% and 52.5% of advisories; the nine without Hitachi Energy account for 60.4%, 56.1% and 47.3% (**Confirmed**, computed). Phoenix Contact's zero most likely reflects where it publishes (**Inferred**): CERT@VDE covers about 40 mostly German automation vendors, Phoenix Contact, WAGO, CODESYS, Beckhoff, Pilz and Festo among them, and its newest advisory on 3 November 2026 was VDE-2026-119 for Welotec [99] (**Confirmed**). Moxa's page shows only seven recent items and gives no yearly counts [52], and Mitsubishi Electric's PSIRT RSS feed is not a complete list [53] (**Confirmed**).

Siemens publishes more than CISA republishes, but only slightly: its CSAF feed lists 156, 141 and 105 advisories first published in 2024, 2025 and 2026, against CISA's 150, 133 and 103 Siemens advisories by folder year [39] [37] (**Confirmed** for the counts). That CISA is a near-complete mirror is **Inferred** from the totals; advisories were not matched one by one.

2.3 Why the CVE count is mostly Siemens third-party code

Siemens advisories carry 70.0% (2024), 59.2% (2025) and 50.9% (2026) of each year's unique CVEs [37] (**Confirmed**, computed). Most of that weight is a few bulletins for Linux-based subsystems and third-party components: ICSA-24-102-01 has 455 CVEs, ICSA-25-226-07 has 486 and ICSA-26-295-11 has 428 [37] (**Confirmed**). Their per-CVE notes name Apache httpd, Python, QEMU, dnsmasq, the Linux kernel and Android [37]. ICSA-26-295-11, for the S7-1500 CPU 1518(F)-4 PN/DP MFP, says Siemens is preparing fixes and offers mitigations only [37] (**Confirmed**). For a defender, a CVE count from these bulletins measures the size of an embedded operating system, not the attack surface of a controller (**Inferred**).

2.4 Weakness classes

Counted per vulnerability row, CWE-20 leads every year (268, 544 and 793 rows), but that is an artifact: ICSA-24-102-01 contributes 127 rows, ICSA-25-226-07 contributes 308, and ICSA-26-295-16 and ICSA-26-295-11 contribute 244 and 204 [37] (**Confirmed**). Counted once per advisory the picture changes:

Year	Most common CWEs, counted once per advisory
2024	CWE-20 (53), CWE-125 (41), CWE-787 (40)
2025	CWE-787 (48), CWE-306 (46), CWE-125 (40)
2026	CWE-306 (78), CWE-787 (42), CWE-79 (37), CWE-798 (34)

Source: [37] (**Confirmed**, computed). Leaving Siemens out, 2026 is led by authentication and credential weaknesses: CWE-306 Missing Authentication for Critical Function in 71 advisories, CWE-798 Hard-coded Credentials in 33, CWE-307 Excessive Authentication Attempts in 24 and CWE-522 Insufficiently Protected Credentials in 24 [37] (**Confirmed**). Non-Siemens CWE-306 rose from 20 (2024) to 38 (2025) to 71 (2026) while CWE-787 fell from 35 to 23 between 2025 and 2026 [37]. The shift toward missing authentication is **Inferred**, and it matches the attacks in Part 1, which used authentication that was absent or default.

2.5 The exploitation signal: KEV

The KEV catalog held 1,767 entries on 3 November 2026: 186 added in 2024, 245 in 2025 and 283 in 2026 [40] [41] (**Confirmed**). Only 5 of the 714 entries added since 1 January 2024 cite a CISA ICS advisory: CVE-2019-7256 (Nice Linear eMerge), CVE-2025-0994 (Trimble Cityworks), CVE-2018-4063 (Sierra Wireless AirLink), CVE-2021-22681 (Rockwell) and CVE-2023-4346 (KNX) [40] (**Confirmed**). Of the 2,426 CVEs in 2026 ICS advisories, 21 are in KEV, and 19 of them are IT components: PAN-OS and Fortinet in Siemens RUGGEDCOM APE1808, Linux kernel CVEs in SIMATIC S7-1500 MFP and B&R, Chromium in Siemens CADRA and ICONICS, Erlang/OTP CVE-2025-32433 in SINEC OS, ActiveMQ in Hitachi Energy SOI, MongoDB CVE-2025-14847 in ABB Zenon [37] [40] (**Confirmed**). Only Lantronix CVE-2025-67038 and Siemens Software Center CVE-2026-110936 are OT-vendor CVEs [37] [40].

The gap from NVD publication to KEV addition for OT-product entries added 2024 to 2026:

CVE	Product	NVD published	KEV added	Days
CVE-2025-0994	Trimble Cityworks	2025-02-06	2025-02-07	1
CVE-2026-110936	Siemens Software Center	2026-10-15	2026-10-20	5
CVE-2025-20352	Cisco IOS SNMP	2025-09-24	2025-09-29	5

CVE	Product	NVD published	KEV added	Days
CVE-2025-1316	Edimax	2025-03-05	2025-03-19	14
CVE-2024-8956	PTZOptics	2024-09-17	2024-11-04	48
CVE-2024-8957	PTZOptics	2024-09-17	2024-11-04	48
CVE-2025-32433	Erlang/OTP SSH	2025-04-16	2025-06-09	54
CVE-2025-67038	Lantronix	2026-03-11	2026-06-23	104
CVE-2024-54085	AMI MegaRAC	2025-03-11	2025-06-25	106
CVE-2021-26829	OpenPLC ScadaBR	2021-06-11	2025-11-28	1,631
CVE-2021-26828	OpenPLC ScadaBR	2021-06-11	2025-12-03	1,636
CVE-2019-7256	Nice Linear eMerge	2019-07-02	2024-03-25	1,728
CVE-2021-22681	Rockwell Logix	2021-03-03	2026-03-05	1,828

Source: NVD CVE API records, including the `cisaExploitAdd` date [42] (**Confirmed**). The median is 54 days; four are within 30 days and four are over a year. Grouping Erlang/OTP SSH, Cisco IOS SNMP and Siemens Software Center with OT products is this study's choice, and the link of CVE-2025-20352 to Rockwell Stratix switches was not checked.

Three entries show the extremes. Trimble Cityworks CVE-2025-0994 (CWE-502) entered KEV the day after publication, and ICSA-25-037-04 says CISA had received reports of active exploitation and tags the water sector [46] [42] (**Confirmed**). Siemens SSA-580366 for Software Center (CVE-2026-110936, CWE-427, CVSS 3.1 6.7 and 4.0 8.4, reported by Huntress Labs) was revised on 19 October to reference active exploitation, entered KEV the next day and was republished as ICSA-26-295-03 [44] [40] [45] (**Confirmed**). Rockwell CVE-2021-22681 (CWE-522) waited five years: the original advisory gives it CVSS 3 10.0 and says no known public exploits target it [43] (**Confirmed**).

2.6 What the advisories say about exploitation, and how they score it

CISA's "no known public exploitation" line appears in 243 advisories with 2024 ids, 269 with 2025 ids and 253 with 2026 ids; the positive statement that CISA received reports of active exploitation appears in about one advisory a year (ICSA-24-030-04 and ICSA-25-037-04; in 2026 ICSA-26-295-03 points to a vendor blog instead) [37] (**Confirmed**, computed). The line is not always kept current: Lantronix ICSA-26-069-02 Update B of 8 October 2026 still reads "No known public exploitation specifically targeting these vulnerabilities has been reported to CISA" [47], more than three months after CVE-2025-67038 (CWE-78, CVSS 3.1 9.8) entered KEV [40] (**Confirmed**).

The scoring is changing. CVSS 4.0 vectors appear alongside CVSS 3.x in 177 of 422 advisories (42%) for 2024 ids, 269 of 506 (53%) for 2025 and 295 of 461 (64%) for 2026 [37] (**Confirmed**, computed; for 2024, 174 of the 177 carry 3.1 specifically). The CSAF files also started carrying per-vulnerability SSVC vectors in 2026: 225 advisories with 2026 ids have one, against 5 and 10 for the earlier years, with the earliest timestamp on 31 March 2026 [37] (**Confirmed**). The 2026 rows split 299 E:N/A:N, 278 E:N/A:Y, 31 E:P and 1 E:A, and the single "active" row is CVE-2019-11043 in ICSA-26-239-02 [37] (**Confirmed**). The research for this study found no CISA announcement of the change, a negative that is only as good as the search. CISA's own SSVC page describes five decision points and four outcomes (Track, Track*, Attend, Act) and does not mention ICS or

CSAF [48] (**Confirmed**).

Dragos puts the same gap in its own terms: 25% of 2025 ICS advisories had no patch or mitigation, 52% needed Dragos-supplied alternative mitigations, 4% were actively exploited, and its Now, Next and Never split of vulnerabilities was 3%, 71% and 27% [27] (**Confirmed** as Dragos's figures).

2.7 The library's own feed

The Team Star Wolf Intelligence Hub history files hold 443, 489 and 406 `cisa-ics-advisories` rows for 2024, 2025 and 2026, or 1,338 unique ids, all of which exist in the CSAF tree; the tree has 1,389 for those years, so the hub is missing 51 (3, 15 and 33), and its last 2026 ICS row is dated 2026-10-15 [38] [37] (**Confirmed**). The hub dates each row by the CSAF `initial_release_date`, so it buckets republished vendor advisories by the vendor's date [38]. Its ICS rows carry no CWE, CVSS or SSVC fields (49 rows carry a severity label), and `exploitation` reads "unknown" on every row [38] (**Confirmed**). NVD and MSRC rows stop at exactly 1,500 per source per year where they reach it, which suggests a cap (**Inferred**). The hub's 2026 KEV ledger holds the same 283 CVEs as CISA's feed, an exact match on 3 November 2026 [38] [40] (**Confirmed**).

Part 3: how the attacks and the CVEs relate

3.1 Most incidents used no CVE

Incident	How the actors got in, as the source states it	CVE named by the source	Sources
Unitronics wave, 2023 to 2024	Default or no password on TCP 20256	None in the attack; CVE-2023-6448 (CWE-1188, CWE-798) was assigned to the default password afterwards and added to KEV on 2023-12-11	[1] [42]
IOCONTROL, 2023 to 2024	Deployment method unclear	None in the article body	[3]
CARR, NoName057(16), Z-Pentest and Sector16 HMI intrusions	Exposed VNC on 5900 to 5910; default, weak or no password	None	[12]
FrostyGoop, Lviv, 2024	An undetermined vulnerability in MikroTik routers, as reported; ATT&CK C0041 maps Exploit Public-Facing Application	None in the sources opened	[4] [72]
Fuxnet, 2024	SSH, probably after obtaining root passwords; known IRZ router flaws do not give zero-click code execution	None	[61]
Volt Typhoon, 2024 advisory	Edge appliances	CVE-2022-42475 only	[6]
Forescout honeypot, 2025	Default credentials	CVE-2021-26828 (March) and CVE-2021-26829 (September)	[18]
Bremanger dam, 2025	Not stated	None reported	[15]
Poland, December 2025	RTU firmware via the web interface "Default" account; secure update off; ESET has no visibility into initial access	CVE-2024-2617 would have bypassed secure update but was not needed	[21] [22]
AA26-097A, 2026	Opportunistic access to exposed, misconfigured PLCs on 44818, 2222, 102 and 502	None on the web page; the PDF points Rockwell owners to PN1550 for CVE-2021-22681	[29] [30]
US water, July 2026	Remote access to internet-facing MicroLogix; IP addresses and passwords changed	None	[31]

The pattern in the table is **Inferred**: none of the disruptive 2024 to 2026 events with a stated access path depended on a newly disclosed ICS vulnerability. Where a CVE did appear, it was old (ScadaBR, Rockwell, FortiGate), assigned after the fact (Unitronics), or unnecessary (the Hitachi bypass).

3.2 Where the CVE record and the attack record meet

- **CVE-2021-22681 and the 2026 PLC campaign.** CISA added the Rockwell Logix key flaw to KEV on 5 March 2026, the same day as Hikvision CVE-2017-7921 and a month before AA26-097A [42] [40] (**Confirmed**). The advisory PDF points Rockwell owners to PN1550 for this CVE [30], and CISA's Vulnrichment record rates it Exploitation active, Automatable yes, Technical Impact total [50] (**Confirmed**). The KEV entry names no actor, and the advisory web page names no CVE [40] [29]. That the KEV addition reflects this campaign is **Inferred**.
- **ScadaBR and the hacktivists.** Forescout recorded CVE-2021-26828 exploitation from Russian-linked IPs on 1 to 3 March 2025 and TwoNet's CVE-2021-26829 defacement in September 2025 [18]; KEV added the two on 3 December and 28 November 2025 [40] (**Confirmed**). That the honeypot activity and the KEV additions describe the same wider exploitation is **Inferred**.
- **Sierra Wireless AirLink.** Dragos reports VOLTZITE reaching pipeline operations through AirLink gateways in 2025 [26], and KEV added AirLink CVE-2018-4063 on 12 December 2025 [40] (**Confirmed** for each). No source opened ties the CVE to VOLTZITE, so any link is **Inferred** at most.
- **Cisco routers and FSB Center 16.** CERT Polska saw compromised Cisco routers in the Polish attack infrastructure [21], and the FBI says FSB Center 16 exploits CVE-2018-0171 on end-of-life Cisco devices and showed interest in ICS protocols [54] (**Confirmed** for each). Whether the Polish routers were taken through that CVE was not checked.

3.3 The lineage: tools the period is compared to

Tool or event	What the record says	CVE	Attribution	Sources
TRITON / HatMan (2017)	Targets Triconex Tricon MP 3008 firmware 10.0 to 10.4 safety controllers	CVE-2018-7522, CVE-2018-8872 (CWE-119), which HatMan specifically targets	Treasury sanctioned TsNIIKhM for building the tools; it also notes reported scanning of at least 20 US electric utilities in 2019	[60] [59]
PIPEDREAM / INCONTROLLER (2022)	Uses native functionality, not Schneider or Omron vulnerabilities; not used for destructive effect (Dragos, high confidence)	CVE-2020-15368 in the ASRock AsrDrv103.sys driver	CHERNOVITE, no country (Dragos); very likely state sponsored, Russia link largely circumstantial (Mandiant); AA22-103A names no nation	[56] [57] [58] [73]
Ukraine substation outage (October 2022)	Native MicroSCADA scilc.exe on an end-of-life version with default SCIL-API access	None; initial access unknown	Sandworm (Mandiant)	[55]
Industroyer2 (2022)	ATT&CK maps T0802, T0806, T0836, T0801, T0888, T0881 and T1692.001	n/a	Sandworm Team	[74]

The lesson these older cases share with 2024 to 2026 is the same as Part 3.1: the most capable ICS tools abused native protocol and engineering functions, and the CVEs involved sat at the edges, a signed driver or a safety-controller firmware flaw (**Inferred**).

Part 4: attribution

4.1 How the naming systems work

The Diamond Model describes each intrusion event by adversary, infrastructure, capability and victim, links events into activity threads, and groups them into activity groups weighted by a confidence it leaves purposefully undefined [62] (**Confirmed**). It also separates the operator who carries out an intrusion from the customer who benefits, a split that matters for attribution [62] (**Confirmed**). Dragos built its threat groups on that model, names them after minerals, says groups are not static and that most analysts lack the data to group by actor, and warns against cross-vendor "Rosetta Stone" mappings the original analysts did not make [63] (**Confirmed**). Its BAUXITE profile states plainly that "Dragos does not corroborate nor conduct political attribution to threat activity." [64] (**Confirmed**). Mandiant starts a UNC cluster from one defining characteristic and lets it grow, merge, split or graduate to an APT or FIN group, which typically takes years [65] (**Confirmed**). Microsoft encodes origin in the family name, Typhoon for China, Sandstorm for Iran and Blizzard for Russia, and uses Storm-#### for groups in development [68] (**Confirmed**).

So when a government names a sponsor and a vendor names a cluster, they are answering different questions: the customer, in Diamond terms, against the operator's observable activity (**Inferred**).

4.2 Alias crosswalk

Cluster	Government framing	Dragos	Mandiant / Google	Microsoft	Others	ATT&CK
CyberAv3ngers	An Iranian IRGC-affiliated persona, reportedly connected to Soldiers of Solomon [1]; IRGC-CEC officials sanctioned [2]; AA26-097A lists the aliases Shahid Kaveh Group, Hydro Kitten, Storm-0784, APT Iran, Bauxite, Mr. Soul, Soldiers of Solomon and UNC5691 [29]	BAUXITE: substantial technical overlaps with the persona [64]; overlaps with activity the US Government assesses is aligned with CyberAv3ngers and IRGC-CEC [26]	UNC5691 (as listed in [29])	Storm-0784 (as listed in [29])	Claroty: believed to be part of IRGC-CEC [3]	G1027 [70]
PYROXENE	n/a	Overlaps with activity the US Government assesses is aligned with IRGC-CEC [26]	n/a	n/a	n/a	none
Sandworm	GRU GTsST unit 74455, which AA25-343A lists as also known as Sandworm Team, Voodoo Bear, Seashell Blizzard and APT44, noting the match may not be 1:1 [12]	ELECTRUM, which overlaps with Sandworm [23] [26]	APT44; CERT-UA's UAC-0099 is a subcluster [8]	Seashell Blizzard [68]	ESET: Sandworm [22]	G0034, with APT44, ELECTRUM and Seashell Blizzard as associated names [77]
CARR	Founded, funded and directed by the GRU (DOJ allegation) [11]; unit 74455 likely supported its creation (AA25-343A) [12]; Russian government-aligned (Treasury) [67]	n/a	Created and controlled by APT44 (TAG); intrusion activity linked to APT44 with high confidence [8]	n/a	n/a	none
Z-Pentest	CARR "also known as" Z-Pentest (DOJ) [11]; a separate group formed September 2024, separate from GRU involvement (AA25-343A) [12]; linked to the Russian state (DDIS, as relayed) [13]	n/a	n/a	n/a	n/a	none
NoName057(16)	A covert project whose members included CISM employees; CISM was set up by order of the Russian President (DOJ) [11]; CISM created it as a covert project (AA25-343A) [12]	n/a	n/a	n/a	n/a	none
Static Tundra cluster	FSB Center 16, also tracked as Berserk Bear and Dragonfly (FBI) [54]	n/a	n/a	Ghost Blizzard [68]	Cisco: Static Tundra; CrowdStrike: Berserk Bear; Symantec: Dragonfly [21]	G0035 Dragonfly, listed on C0063 [79]

Cluster	Government framing	Dragos	Mandiant / Google	Microsoft	Others	ATT&CK
Volt Typhoon	PRC state-sponsored [6]	VOLTZITE overlaps; SYLVANITE (overlaps UNC5221, UNC5174, UNC5291) supplies access [26]	n/a	Typhoon family name, which encodes China [68]	n/a	G1017; SYLVANITE recorded as a separate initial access cluster [78]
AZURITE	n/a	Overlaps Flax Typhoon [26]	n/a	n/a	n/a	none
GRAPHITE	n/a	Strong overlaps with APT28 [5]	n/a	n/a	n/a	none
CHERNOVITE	AA22-103A names "APT actors" only [58]	Developed PIPEDREAM [56]	INCONTROLLER very likely state sponsored [57]	n/a	n/a	S1045 notes some researchers assessed CHERNOVITE developed it [73]
Blackjack	n/a	Pro-Ukraine hacktivist group [5]	n/a	n/a	Claroty: believed affiliated with Ukrainian intelligence [61]	S1157 lists no group [76]

All cells are **Confirmed** as the cited source states them. Reading across a row as proof that two vendors track the same people is the Rosetta Stone error Dragos warns about [63] (**Inferred**).

4.3 The attribution ladder, event by event

Event	Who attributes	Actor named	Confidence or hedge stated	Grade
Unitronics wave	CISA and partners; Treasury	IRGC-affiliated CyberAv3ngers; IRGC-CEC officials	TTPs "likely associated" with the persona	Confirmed [1] [2]
IOCONTROL	Claroty	CyberAv3ngers	"Allegedly" compromised; "believed to be part of" IRGC-CEC	Confirmed [3]
FrostyGoop	Dragos; ATT&CK	None	n/a	Reported [4]; Confirmed [72]
Fuxnet	Claroty; Dragos	Blackjack	"Believed to be affiliated"	Confirmed [61] [5]
CARR water and hydro videos	Mandiant	CARR, linked to APT44	Claims and their APT44 link not verified	Confirmed [8]
Volt Typhoon	CISA, NSA, FBI	PRC state-sponsored Volt Typhoon	High confidence	Confirmed [6]
Littleton utility	Dragos, as told to SecurityWeek	VOLTZITE / Volt Typhoon	Not checked	Reported [7]
Bremanger dam	PST, as reported	Pro-Russian cyber actors, no group	None; case closed without suspects	Reported [14] [16]
Koege waterworks	DDIS, as reported	Z-Pentest	None reported	Reported [13]
HMI intrusions, 2023 to 2025	CISA and partners; DOJ	CARR, NoName057(16), Z-Pentest, Sector16; GRU and CISM support	"Likely"; Sector16 "may have received indirect support"	Confirmed [12] [11]
Poland, December 2025	CERT Polska / ESET / Dragos	Static Tundra cluster / Sandworm / ELECTRUM	Infrastructure overlap / medium / moderate	Confirmed [21] [22] [23]
PLC campaign, 2026	Seven US agencies	Iranian-affiliated APT actors	Assessed, no level stated; CyberAv3ngers only as "similar"	Confirmed [29]
US water, July 2026	FBI and EPA; CISA	None	n/a	Confirmed [31] [32]

4.4 Personas and fronts: what the evidence for the links looks like

Mandiant's case for tying the Russian personas to APT44 rests on infrastructure and timing, not on claims. A unique APT44 artifact appeared in a XakNet leak; CADDYWIPER wipes were followed by Telegram leaks within 24 hours; and in at least a third of CARR's leaks Mandiant observed APT44 intrusions on the same victims in the 24 hours before; it grades the persona links at moderate confidence [66] (**Confirmed**). Google TAG saw CARR's YouTube channel created from APT44 infrastructure, APT44 infrastructure exfiltrated data that CARR later leaked, and in one case operator errors made a CARR claim appear before the attack it described [8] (**Confirmed**). Mandiant had first put this activity on APT28, because both groups were in the same network, and re-analysis moved it to APT44 with high confidence [8] (**Confirmed**). That high-confidence link concerns the intrusion activity Mandiant re-analysed, not the unverified water and hydro claims, which it could not verify [8].

The US government record on the same personas is not internally consistent. The DOJ calls CARR "also known as Z-Pentest" [11], while AA25-343A treats Z-Pentest as a separate group formed in September 2024 by CARR administrators dissatisfied with GRU support, together with a NoName057(16) administrator, and operating separately from the GRU [12]; DDIS links Z-Pentest to the Russian state [13] (**Confirmed** for each statement; the inconsistency is **Inferred**). This study presents all three framings and does not merge them. AA25-343A also says the groups often make false or exaggerated claims and portray minor incursions as significant breaches [12] (**Confirmed**), which fits Fuxnet's 500 against 87,000 [61] and TwoNet's honeypot claim [18].

4.5 The contested case: Poland

CERT Polska found that the attack infrastructure (compromised VPS and Cisco routers used for initial access, exfiltration, VPN tunnels and RAID damage) overlaps with the cluster known as Static Tundra, Berserk Bear, Ghost Blizzard and Dragonfly, and calls it the first publicly described destructive activity attributed to that cluster [21] [20] (**Confirmed**). It called the similarities between DynoWiper and Sandworm tools very general, found no strong links to known tools, and said it cannot conclusively determine whether the Sandworm cluster took part to any extent [21] (**Confirmed**). The Hacker News reports that the cluster is assessed as linked to FSB Center 16 [24] (**Reported**), and the FBI separately attributes Static Tundra-tracked activity to FSB Center 16 [54] (**Confirmed**).

ESET attributes DynoWiper to Sandworm with medium confidence, covering only the wiper, on the basis of Group Policy deployment and code-logic similarity to the ZOV wiper, which it gives to Sandworm with high confidence; it has no visibility into initial access and lists one factor against Sandworm: its earlier operations in Poland were covert or disguised as ransomware [22] (**Confirmed**). As a precedent, ESET notes that in 2025 UAC-0099 handed Ukrainian targets off to Sandworm, so another group may have done the preparatory stages [22] (**Confirmed**). Dragos assesses with moderate confidence that ELECTRUM, which overlaps with Sandworm, was responsible, and that the attack did not achieve the coordinated operational impact of earlier ELECTRUM operations [23] (**Confirmed**). ATT&CK C0063 carries both readings, Dragonfly in "some reporting" and Sandworm Team in "other reporting" [79] (**Confirmed**).

The three attributing sources point to Russian state-linked clusters and disagree on which service ran the operation (**Inferred**). Both readings can be true if one group built access and another ran the wiper, which is the operator and customer split of Part 4.1 and the access-handoff pattern ESET and Dragos each describe [22] [27] (**Inferred**).

4.6 False flags and weak evidence

Self-claims are the weakest evidence in this record, and code features can be planted. Kaspersky found that Olympic Destroyer's Rich header had been forged to match Lazarus and caught it by checking the header's features against the actual code [69] (**Confirmed**). Read the evidence types in this study from strongest to weakest: legal process and sanctions [11] [2] [67]; infrastructure overlap observed by a responder [21] [8]; code similarity [22]; timing correlation [66]; and persona claims [8] [18] (the ranking is **Inferred**). Shared tradecraft is weak evidence in ICS: Iranian-affiliated actors, Russian-aligned personas and unnamed actors all used default credentials on exposed HMIs and PLCs [1] [12] [31] (**Inferred**).

4.7 What links the events

Three kinds of relationship recur in the verified record (**Inferred** as a model, each instance **Confirmed** in its source):

1. **State service to persona.** IRGC-CEC to CyberAv3ngers [2] [3]; GRU to CARR [11] [12]; CISM to NoName057(16) [12].
2. **Access broker to operator.** SYLVANITE to VOLTZITE, a handoff Dragos says it observed directly [27]; UAC-0099 to Sandworm in Ukraine in 2025 [22].
3. **Shared method without a shared actor.** Default credentials on exposed devices across Iranian, Russian-aligned and unnamed activity [1] [12] [18] [31].

Part 5: the defender view

5.1 How much is exposed

The counts depend on who counts and how. Censys's 2024 report found over 148,000 exposed ICS services in 175 countries (its summary prints "145,00", a typo), 38% in North America and 35% in Europe, and over 7,700 exposed HMIs in 80 countries, nearly 70% in North America; AutomationDirect C-More was the most common HMI, and over a third of C-More exposures were water-related; it does not define a "service" [83] (**Confirmed**). SANS ISC counted about 111,100 ICS-tagged devices on Shodan in April 2024, up from 80,800 in May 2021 (33,036 on Modbus), about 106,200 on Censys for common industrial protocols and about 61,700 on Shadowserver, and warned that honeypots and definitions make every count an estimate [84] (**Confirmed**). Unit 42 counted 1,088,175 internet-exposed Modbus TCP devices between 2 September and 2 October 2024 [85] (**Confirmed**). Claroty's analysis of about a million OT devices found 12% (111,000) with KEVs and 40% of organizations with some of those assets insecurely connected to the internet [94] (**Confirmed**).

Scanners find non-standard ports too. A Censys honeypot logged 764 events from 188 IPs over nine days in November and December 2025, 51.7% S7comm and 25.0% Modbus; 26% of scanners were ICS-aware, Modbus carried the exploit-tagged traffic, and Censys concludes that port changes alone do not prevent discovery [86] (**Confirmed**).

5.2 The baseline controls

The joint CISA, FBI, EPA and DOE primary mitigations are short: remove OT internet connections, change default passwords, secure remote access with a private IP connection and a VPN with phishing-resistant MFA, segment IT and OT with a DMZ, and practise manual operation [90] (**Confirmed**). AA26-097A adds PLC-specific steps: broker access through a jump host, use a private APN or ZTNA for cellular modems, block hosting-provider traffic, disable Telnet, FTP, RDP and VNC, set the Rockwell mode switch to RUN, enable Siemens programming protection, compare running logic to known-good copies and verify backups [29] (**Confirmed**). AA24-038A advises denying IT-to-OT connections by default and routing what is needed through a monitored DMZ or jump box [6] (**Confirmed**).

EPA's May 2024 enforcement alert found that over 70% of water systems inspected since September 2023 violated basic Section 1433 requirements, with examples such as unchanged default passwords, one login for all staff and former employees who kept access [89] (**Confirmed**). The CISA-led OT asset inventory guidance

sets five steps (scope, identify assets and collect attributes, taxonomy with zones and conduits, data management, life cycle), and its high-priority attributes include protocols, criticality, IP and MAC, manufacturer, model, OS, location, ports and services, user accounts and logging [87] (**Confirmed**). NIST SP 800-82r3 offers the Purdue model, ISA-95 levels or a three-tier IIoT architecture to organize segmentation, with a DMZ example [88] (**Confirmed**). The NCSC-led secure connectivity principles name legacy devices, remote access arrangements and complex vendor supply chains as connectivity risks [91] (**Confirmed**).

Dragos's assessments show how far practice is from that baseline: 81% found poor IT and OT segmentation, 73% of its all-time incident response cases involved compromised VPN or jump-host credentials, and only 46% found adequate OT network monitoring [27] (**Confirmed** as Dragos's figures). Nozomi's second-half 2025 data has adversary-in-the-middle in over a quarter of alerts and 802.1x on only 0.3% of observed Wi-Fi networks [95] (**Confirmed** as Nozomi's figures).

5.3 Prioritizing ICS vulnerabilities

The CVSS score alone is a poor guide. CODESYS CVE-2025-41660 has a CNA CVSS of 8.8, but CISA's Vulnrichment SSVC record rates it Exploitation none, Automatable no, Technical Impact total [51] (**Confirmed**); it can wait behind a lower-scored flaw that is exploited (**Inferred**). Vulnrichment adds Exploitation, Automatable and Technical Impact to every CVE it analyzes, plus CWE and CVSS when the evidence supports them, and stopped adding CPE strings on 10 December 2024 [49] (**Confirmed**). The CISA SSVC guide's Public Well-Being decision point counts reduced cyber-physical safety margins as "Material" [92] (**Confirmed**), which is the point where OT differs from IT.

BOD 26-04 sets remediation urgency from Asset Exposure, KEV status, Exploit Automation and Technical Impact, informed by SSVC and fed by Vulnrichment; taking a system off the internet changes its exposure value and lengthens its timeline; the directive does not mention OT [93] (**Confirmed**). Applied to OT, that logic makes removing exposure the fastest way to buy time, which is also the first mitigation in Part 5.2 (**Inferred**). Claroty's advice is the same in practice: fix first the devices that have KEVs, are insecurely exposed and are at risk of ransomware [94] (**Confirmed**).

A workable order for an OT team, drawn from the sources above (**Inferred**): (1) any KEV CVE on an internet-exposed OT asset; (2) default and missing credentials, which have no CVE but carried most of Part 1; (3) KEV CVEs in the IT components inside OT products, patched like IT; (4) SSVC Exploitation P or Automatable yes on assets that matter; (5) the rest at the next maintenance window, with the vendor's mitigations where no fix exists.

5.4 Detecting the 2026 PLC campaign

AA26-097A maps its own observations to ICS T0883 and T0885 and Enterprise T1219, T1041 and T1565, with indicator IP windows from January 2025 to July 2026 [29] (**Confirmed**). The advisory's detection value is in its behavior: programming-software sessions from leased hosting, Dropbear SSH on modems and logic changes [29].

5.5 Open-tooling detection

Suricata has protocol keywords for Modbus (function, read or write access, unit id), DNP3 and ENIP/CIP (`enip_command`, and `cip_service` taking service, class and attribute) [96] (**Confirmed**). Wazuh's proof-of-concept guide reads Suricata's `eve.json` through a `localfile` block with `log_format json`, uses the Emerging Threats ruleset and filters alerts with `rule.groups:suricata` [97] (**Confirmed**). A detection for AA26-097A-style activity follows from those pieces: Suricata rules on ENIP/CIP program or mode-change services and on Modbus write function codes from any host that is not an engineering workstation, sent to Wazuh. Because Censys reports that even protocol-aware scanners stopped short of write or control operations [86], a write from an unexpected source is high-signal (**Inferred**; the Censys page also shows a write request in one example session, and the rule is not tested against a live rule set).

5.6 Mitigations mapped

ATT&CK for ICS mitigation M0930 Network Segmentation covers, among the techniques in this study, T0806, T0816, T0822, T0838, T0843, T0845, T0846, T0869, T0878, T0883, T0885, T0886, T1692, T1693 and T1695 [80] [82] (**Confirmed**). In the library's ICS profiles, M0801 Access Management and M0927 Password Policies cover T1694.001 Default Credentials, and M0953 Data Backup covers T0826, T0829 and T0809 [82] (**Confirmed**). Part 6.5 lists the rest.

5.7 Library corrections

- `data/attack/ics/group_to_technique.jsonl` lacks T0814 and T0828 for G1027, both of which the live page (modified 2026-10-07) lists [82] [70] (**Confirmed**).
- The library has no generated ICS technique or ICS mitigation pages, and no pages for G1027, G1000, S1045, S1165, S1157, S1009 or C0031 [82] (**Confirmed**).
- `THREAT_ACTORS.md` has an Iran-table row named "Volt Typhoon lookalike", with ATT&CK id "None" and "Cyber Av3ngers (IRGC)" as its alias; ATT&CK has CyberAv3ngers as G1027 [82] [70] (**Confirmed**).
- `MALWARE_FAMILIES.md` and `NOTABLE_INCIDENTS.md` have no entries for FrostyGoop, Fuxnet, IOCONTROL or DynoWiper (searched on main `e85b559`) [82] (**Confirmed**).
- The library's D3FEND data keys its ICS credential countermeasures to the revoked T0812 rather than T1694.001; for example D3-CDP Change Default Password lists T0812 [82] (**Confirmed**).
- Advisories still cite revoked ICS ids; Part 6.4 maps them.

Part 6: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 for Enterprise and for ICS, CWE, CAPEC and D3FEND. Every technique id below is a live id in the library's `data/attack/ics/technique_profiles.jsonl` or `data/attack/technique_profiles.jsonl`, which supply the names and tactics, and every mapping comes from a cited advisory or a live ATT&CK page [82]. Mappings no source states are left out; behaviors in Part 1 that no source maps (for example the Forescout webshell) are not given ids here.

6.1 Objects

Object	ATT&CK id	Library page	Relationship to this study
CyberAv3ngers	G1027	none (no generated page)	19 ICS techniques; v1.1, modified 2026-10-07; notes disputed and false claims of compromises in Israel [70]
Unitronics Defacement Campaign	C0031	none	November 2023; attributed to G1027 [71]
IOControl	S9046	/mitre/software/S9046.md	Created 2026-09-02; attributed to CyberAv3ngers; 4 ICS and 9 Enterprise techniques [75]
FrostyGoop	S1165	none	Associated name BUSTLEBERM; no group [72]
FrostyGoop Incident	C0041	/mitre/campaigns/C0041.md	January 2024, Ukraine district heating [72]
Fuxnet	S1157	none	No group object; the description mentions Blackjack as assessed linked to Ukrainian intelligence [76]
2025 Poland Wiper Attacks	C0063	/mitre/campaigns/C0063.md	March to December 2025; Dragonfly and Sandworm Team in "some" versus "other" reporting; 21 ICS technique rows (24 layer entries with parents) [79]
DynoWiper	S9038	/mitre/software/S9038.md	The wiper ESET attributes to Sandworm at medium confidence [22] [82]
LazyWiper	S9039	/mitre/software/S9039.md	The PowerShell wiper CERT Polska says cannot be used for attribution [21] [82]
Dragonfly	G0035	/mitre/groups/G0035.md	STATIC TUNDRA reading of C0063 [79]
Sandworm Team	G0034	/mitre/groups/G0034.md	v4.2; GRU GTsST unit 74455; APT44, ELECTRUM and Seashell Blizzard as associated names; campaigns C0025, C0028, C0034 [77]
Volt Typhoon	G1017	/mitre/groups/G1017.md	v2.0; Enterprise only, no ICS techniques; campaigns C0035 and C0039; SYLVANITE noted as a separate access cluster [78]
KV Botnet Activity	C0035	/mitre/campaigns/C0035.md	Volt Typhoon campaign [78]
Versa Director Zero Day Exploitation	C0039	/mitre/campaigns/C0039.md	Volt Typhoon campaign [78]
Industroyer2	S1072	/mitre/software/S1072.md	Lineage (Part 3.3) [74]
Industroyer	S0604	/mitre/software/S0604.md	Lineage; tied to G0034 and C0025 [74]
2016 Ukraine Electric Power Attack	C0025	/mitre/campaigns/C0025.md	Lineage [74] [77]
2015 Ukraine Electric Power Attack	C0028	/mitre/campaigns/C0028.md	Lineage [77]

Object	ATT&CK id	Library page	Relationship to this study
2022 Ukraine Electric Power Attack	C0034	/mitre/campaigns/C0034.md	Lineage; the substation outage of Part 3.3 [55] [77]
INCONTROLLER	S1045	none	No group; some researchers assessed CHERNOVITE developed it; 22 ICS entries counting parents [73]
Triton Safety Instrumented System Attack	C0030	/mitre/campaigns/C0030.md	Lineage; the library page names TEMP.Veles (/mitre/groups/G0088.md); the Triton software S1009 has no library page [82]

CARR, NoName057(16), Z-Pentest, Sector16, TwoNet, Blackjack and the Dragos and Mandiant cluster names have no ATT&CK group object in the sources opened, so none is given here.

6.2 ATT&CK for ICS techniques (43)

The library has no per-technique ICS pages, so ids link to attack.mitre.org; the library's ICS ATT&CK Technique Atlas groups them by tactic. Each row names every bound event in which the technique appears.

ID	Name	Tactic(s)	Dated event or report	Sources
T0801	Monitor Process State	Collection	S1165 FrostyGoop software record	[72]
T0806	Brute Force I/O	Impair Process Control	S1157 Fuxnet (Apr 2024)	[76]
T0809	Data Destruction	Inhibit Response Function	C0063 2025 Poland Wiper Attacks (29 Dec 2025); S1157 Fuxnet (Apr 2024)	[76] [79]
T0814	Denial of Service	Inhibit Response Function	C0031 Unitronics Defacement Campaign (Nov 2023); G1027 CyberAv3ngers record (page modified 2026-10-07); S1157 Fuxnet (Apr 2024)	[70] [71] [76]
T0816	Device Restart/Shutdown	Inhibit Response Function	C0063 2025 Poland Wiper Attacks (29 Dec 2025); AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12] [79]
T0822	External Remote Services	Initial Access	C0063 2025 Poland Wiper Attacks (29 Dec 2025); S1157 Fuxnet (Apr 2024)	[76] [79]
T0823	Graphical User Interface	Execution	C0063 2025 Poland Wiper Attacks (29 Dec 2025); AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12] [79]
T0826	Loss of Availability	Impact	C0031 Unitronics Defacement Campaign (Nov 2023); G1027 CyberAv3ngers record (page modified 2026-10-07); C0041 FrostyGoop Incident (Jan 2024)	[70] [71] [72]
T0827	Loss of Control	Impact	G1027 CyberAv3ngers record (page modified 2026-10-07); C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[70] [79]
T0828	Loss of Productivity and Revenue	Impact	C0031 Unitronics Defacement Campaign (Nov 2023); G1027 CyberAv3ngers record (page modified 2026-10-07); AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12] [70] [71]

ID	Name	Tactic(s)	Dated event or report	Sources
T0829	Loss of View	Impact	C0031 Unitronics Defacement Campaign (Nov 2023); G1027 CyberAv3ngers record (page modified 2026-10-07); C0041 FrostyGoop Incident (Jan 2024); C0063 2025 Poland Wiper Attacks (29 Dec 2025); S1157 Fuxnet (Apr 2024); AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12] [70] [71] [72] [76] [79]
T0831	Manipulation of Control	Impact	AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12]
T0836	Modify Parameter	Impair Process Control	AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09); C0041 FrostyGoop Incident (Jan 2024); S1165 FrostyGoop software record	[12] [72]
T0838	Modify Alarm Settings	Inhibit Response Function	G1027 CyberAv3ngers record (page modified 2026-10-07)	[70]
T0840	Network Connection Enumeration	Discovery	C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[79]
T0843	Program Download	Lateral Movement	G1027 CyberAv3ngers record (page modified 2026-10-07)	[70]
T0845	Program Upload	Collection	G1027 CyberAv3ngers record (page modified 2026-10-07)	[70]
T0846	Remote System Discovery	Discovery	C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[79]
T0846.001	Port Scan	Discovery	C0063 2025 Poland Wiper Attacks (29 Dec 2025); S9046 IOControl (Claroty report 2024-12-10)	[75] [79]
T0846.002	Broadcast Discovery	Discovery	C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[79]
T0852	Screen Capture	Collection	C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[79]
T0859	Valid Accounts	Persistence, Lateral Movement	AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09); C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[12] [79]
T0869	Standard Application Layer Protocol	Command and Control	S1165 FrostyGoop software record	[72]
T0869.001	DNS	Command and Control	S9046 IOControl (Claroty report 2024-12-10)	[75]
T0869.002	Publish/Subscribe Protocols	Command and Control	S9046 IOControl (Claroty report 2024-12-10)	[75]
T0871	Execution through API	Execution	G1027 CyberAv3ngers record (page modified 2026-10-07)	[70]
T0878	Alarm Suppression	Inhibit Response Function	AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12]
T0879	Damage to Property	Impact	G1027 CyberAv3ngers record (page modified 2026-10-07)	[70]

ID	Name	Tactic(s)	Dated event or report	Sources
T0880	Loss of Safety	Impact	G1027 CyberAv3ngers record (page modified 2026-10-07)	[70]
T0882	Theft of Operational Information	Impact	C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[79]
T0883	Internet Accessible Device	Initial Access	C0031 Unitronics Defacement Campaign (Nov 2023); G1027 CyberAv3ngers record (page modified 2026-10-07); AA26-097A Iranian-affiliated PLC disruption (from Mar 2026; advisory 2026-04-07); S1157 Fuxnet (Apr 2024); AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12] [29] [70] [71] [76]
T0885	Commonly Used Port	Command and Control	G1027 CyberAv3ngers record (page modified 2026-10-07); AA26-097A Iranian-affiliated PLC disruption (from Mar 2026; advisory 2026-04-07); S1165 FrostyGoop software record; C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[29] [70] [72] [79]
T0886	Remote Services	Initial Access, Lateral Movement	G1027 CyberAv3ngers record (page modified 2026-10-07); C0063 2025 Poland Wiper Attacks (29 Dec 2025); AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12] [70] [79]
T0888	Remote System Information Discovery	Discovery	C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[79]
T0889	Modify Program	Persistence	G1027 CyberAv3ngers record (page modified 2026-10-07)	[70]
T0892	Change Credential	Inhibit Response Function	G1027 CyberAv3ngers record (page modified 2026-10-07); AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09); C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[12] [70] [79]
T1692.001	Command Message	Evasion, Impair Process Control	G1027 CyberAv3ngers record (page modified 2026-10-07); AA25-343A, cited there under a revoked id (see 6.4)	[12] [70] [82]
T1693.001	System Firmware	Persistence, Inhibit Response Function, Impair Process Control	C0041 FrostyGoop Incident (Jan 2024); C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[72] [79]
T1694.001	Default Credentials	Persistence, Lateral Movement	C0031 Unitronics Defacement Campaign (Nov 2023); G1027 CyberAv3ngers record (page modified 2026-10-07); AA25-343A, cited there under a revoked id (see 6.4); C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[12] [70] [71] [79] [82]
T1695	Block Communications	Inhibit Response Function	G1027 CyberAv3ngers record (page modified 2026-10-07)	[70]
T1701	Command and Scripting Interpreter	Execution	S1165 FrostyGoop software record	[72]
T1701.001	PowerShell	Execution	C0063 2025 Poland Wiper Attacks (29 Dec 2025)	[79]

ID	Name	Tactic(s)	Dated event or report	Sources
T1701.003	Unix Shell	Execution	C0063 2025 Poland Wiper Attacks (29 Dec 2025); S9046 IOControl (Claroty report 2024-12-10)	[75] [79]

The ICS techniques ATT&CK lists for older lineage tools (Industroyer2 T0802, T0806, T0836, T0801, T0888, T0881, T1692.001 [74]; INCONTROLLER's 22 entries including T0858, T1694.002, T0843.001, T0861 and T1692.001 [73]; Sandworm Team's T0819, T0822, T1692.001, T1691.001, T1695.001 and T1693.001 from the 2015 attack [77]) are outside this period and are not in the layer.

6.3 ATT&CK Enterprise techniques (79)

The C0063 rows come from the library's campaign data, which mirrors the ATT&CK v20.0 campaign object [79] [82]; the T1003.003 row joins AA24-038A's description of NTDS.dit theft [6] to the library's G1017 group data [82]. For Volt Typhoon, this table keeps only the initial-access and credential techniques that AA24-038A ties to reaching OT (T1078, T1078.002, T1133, T1190 and the NTDS.dit theft, T1003.003). The full G1017 mapping is on /mitre/groups/G1017.md, and AA24-038A's own mapping is in [6]. Ids link to the library's generated technique pages.

ID	Name	Tactic(s)	Dated event or report	Sources
T1003.001	LSASS Memory	Credential Access	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1003.002	Security Account Manager	Credential Access	C0041 FrostyGoop Incident (Jan 2024); C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[72] [79] [82]
T1003.003	NTDS	Credential Access	G1017 Volt Typhoon in the library group data; AA24-038A describes the NTDS.dit theft; C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[6] [79] [82]
T1006	Direct Volume Access	Stealth	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1016	System Network Configuration Discovery	Discovery	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1021.001	Remote Desktop Protocol	Lateral Movement	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1021.005	VNC	Lateral Movement	AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12]
T1027.002	Software Packing	Stealth	S9046 IOControl (Claroty report 2024-12-10)	[75]
T1027.013	Encrypted/Encoded File	Stealth	S9046 IOControl (Claroty report 2024-12-10); C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[75] [79] [82]
T1033	System Owner/User Discovery	Discovery	S9046 IOControl (Claroty report 2024-12-10)	[75]
T1036.005	Match Legitimate Resource Name or Location	Stealth	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]

ID	Name	Tactic(s)	Dated event or report	Sources
T1037.004	RC Scripts	Persistence, Privilege Escalation	S9046 IOControl (Claroty report 2024-12-10)	[75]
T1041	Exfiltration Over C2 Channel	Exfiltration	AA26-097A Iranian-affiliated PLC disruption (from Mar 2026; advisory 2026-04-07)	[29]
T1046	Network Service Discovery	Discovery	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1048.003	Exfiltration Over Unencrypted Non-C2 Protocol	Exfiltration	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1049	System Network Connections Discovery	Discovery	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1053	Scheduled Task/Job	Execution, Persistence, Privilege Escalation	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1057	Process Discovery	Discovery	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1059.003	Windows Command Shell	Execution	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1059.004	Unix Shell	Execution	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1059.008	Network Device CLI	Execution	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1070.004	File Deletion	Stealth	S9046 IOControl (Claroty report 2024-12-10)	[75]
T1070.009	Clear Persistence	Stealth	S9046 IOControl (Claroty report 2024-12-10)	[75]
T1071	Application Layer Protocol	Command and Control	C0041 FrostyGoop Incident (Jan 2024)	[72]
T1074.001	Local Data Staging	Collection	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	G1017 Volt Typhoon record (v2.0)	[78]
T1078.001	Default Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA23-335A Unitronics wave (Nov 2023 to Jan 2024)	[1]
T1078.002	Domain Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	G1017 Volt Typhoon record (v2.0); C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[78] [79] [82]
T1078.004	Cloud Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1082	System Information Discovery	Discovery	S9046 IOControl (Claroty report 2024-12-10)	[75]
T1083	File and Directory Discovery	Discovery	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]

ID	Name	Tactic(s)	Dated event or report	Sources
T1090	Proxy	Command and Control	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1090.003	Multi-hop Proxy	Command and Control	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1102.002	Bidirectional Communication	Command and Control	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1105	Ingress Tool Transfer	Command and Control	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1110	Brute Force	Credential Access	AA23-335A Unitronics wave (Nov 2023 to Jan 2024)	[1]
T1110.002	Password Cracking	Credential Access	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1110.003	Password Spraying	Credential Access	AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12]
T1113	Screen Capture	Collection	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1114.002	Remote Email Collection	Collection	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1124	System Time Discovery	Discovery	S9046 IOControl (Claroty report 2024-12-10)	[75]
T1133	External Remote Services	Persistence, Initial Access	G1017 Volt Typhoon record (v2.0); C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[78] [79] [82]
T1140	Deobfuscate/Decode Files or Information	Stealth	S9046 IOControl (Claroty report 2024-12-10); C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[75] [79] [82]
T1190	Exploit Public-Facing Application	Initial Access	AA24-038A Volt Typhoon pre-positioning (advisory 2024-02-07); G1017 Volt Typhoon record (v2.0); C0041 FrostyGoop Incident (Jan 2024)	[6] [72] [78]
T1219	Remote Access Tools	Command and Control	AA26-097A Iranian-affiliated PLC disruption (from Mar 2026; advisory 2026-04-07)	[29]
T1484.001	Group Policy Modification	Defense Impairment, Privilege Escalation	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1485	Data Destruction	Impact	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1490	Inhibit System Recovery	Impact	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1491.001	Internal Defacement	Impact	AA23-335A Unitronics wave (Nov 2023 to Jan 2024)	[1]
T1495	Firmware Corruption	Impact	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]

ID	Name	Tactic(s)	Dated event or report	Sources
T1499	Endpoint Denial of Service	Impact	AA23-335A Unitronics wave (Nov 2023 to Jan 2024)	[1]
T1505.003	Web Shell	Persistence	C0041 FrostyGoop Incident (Jan 2024)	[72]
T1529	System Shutdown/Reboot	Impact	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1530	Data from Cloud Storage	Collection	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1531	Account Access Removal	Impact	AA23-335A Unitronics wave (Nov 2023 to Jan 2024)	[1]
T1550.002	Pass the Hash	Lateral Movement	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1555	Credentials from Password Stores	Credential Access	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1556.006	Multi-Factor Authentication	Defense Impairment, Persistence, Credential Access	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1558	Steal or Forge Kerberos Tickets	Credential Access	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1560.001	Archive via Utility	Collection	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1565	Data Manipulation	Impact	AA26-097A Iranian-affiliated PLC disruption (from Mar 2026; advisory 2026-04-07)	[29]
T1565.001	Stored Data Manipulation	Impact	AA23-335A Unitronics wave (Nov 2023 to Jan 2024)	[1]
T1567.004	Exfiltration Over Webhook	Exfiltration	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1570	Lateral Tool Transfer	Lateral Movement	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1571	Non-Standard Port	Command and Control	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1583.003	Virtual Private Server	Resource Development	AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12]
T1583.006	Web Services	Resource Development	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1584.001	Domains	Resource Development	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1584.003	Virtual Private Server	Resource Development	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1584.008	Network Devices	Resource Development	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]

ID	Name	Tactic(s)	Dated event or report	Sources
T1587.001	Malware	Resource Development	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1588.007	Artificial Intelligence	Resource Development	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1590.006	Network Security Appliances	Reconnaissance	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1591	Gather Victim Org Information	Reconnaissance	AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12]
T1595.002	Vulnerability Scanning	Reconnaissance	AA25-343A pro-Russia hacktivist HMI intrusions (Oct 2023 to Apr 2025; advisory 2025-12-09)	[12]
T1602.002	Network Device Configuration Dump	Collection	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1608.002	Upload Tool	Resource Development	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1686.002	Network Device Firewall	Defense Impairment	C0063 Poland Wiper Attacks, Enterprise rows in the library campaign data	[79] [82]
T1689	Downgrade Attack	Defense Impairment	C0041 FrostyGoop Incident (Jan 2024)	[72]

6.4 Revoked ids still in the advisories

Id as cited	Where	Status in ATT&CK v20.0	Use instead	Sources
T0812 Default Credentials	AA25-343A; CERT Polska report	Revoked	T1694.001 Default Credentials	[12] [21] [82]
T0855 Unauthorized Command Message	AA25-343A	Revoked	T1692.001 Command Message	[12] [82]
T0857 System Firmware	CERT Polska report	Revoked	T1693.001 System Firmware	[21] [82]
T0807 Command-Line Interface	CERT Polska report	Deprecated, no replacement in superseded_by.jsonl	n/a	[21] [82]
"Module Firmware T0892"	CERT Polska report	T0892 is Change Credential; Module Firmware was T0839	T1693.002 Module Firmware	[21] [81] [82]

6.5 ICS mitigations

Mitigation	Techniques in this study it covers	Source
M0930 Network Segmentation	T0806, T0816, T0822, T0838, T0843, T0845, T0846.001, T0846.002, T0869, T0878, T0883, T0885, T0886, T1692.001, T1693.001, T1695 (live page v1.1 and library profiles agree)	[80] [82]
M0801 Access Management	T1694.001, T0859, T0816, T0838, T0843, T0845, T0871, T0886, T1693.001	[82]
M0927 Password Policies	T1694.001, T0859, T0822, T0886, T0892	[82]
M0953 Data Backup	T0826, T0829, T0809, T0827, T0828, T0831, T0892	[82]
M0932 Multi-factor Authentication	T0822, T0859	[82]
M0804 Human User Authentication	T0816, T0836, T0838, T0843, T0845, T0871, T0885, T0886, T0889, T1693.001	[82]
M0947 Audit	T0836, T0843, T0859, T0889, T1693.001	[82]
M0945 Code Signing	T0843, T0889, T1693.001, T1701.001	[82]
M0942 Disable or Remove Feature or Program	T0816, T0822, T0885, T1701, T1701.001	[82]

Each row lists only the techniques of Part 6.2 that the mitigation covers.

6.6 Vulnerabilities, CWE and CAPEC

CVE	Product	CWE (as the source lists it)	CAPEC the library relates to that CWE	Where it meets the record	Sources
CVE-2023-6448	Unitronics VisiLogic	CWE-1188, CWE-798	3 entries: CAPEC-70 Try Common or Default Usernames and Passwords (maps T1078.001) and CAPEC-191 Read Sensitive Constants Within an Executable from CWE-798, and CAPEC-665 Exploitation of Thunderbolt Protection Flaws from CWE-1188, which does not fit this default-password case (**Inferred**)	The default password of the 2023 to 2024 wave	[42] [82]
CVE-2021-22681	Rockwell Logix controllers	CWE-522	13 entries, for example CAPEC-560 Use of Known Domain Credentials and CAPEC-600 Credential Stuffing; none describes key recovery from engineering software (**Inferred**)	KEV 2026-03-05; PN1550 in AA26-097A	[42] [43] [30] [82]
CVE-2025-0994	Trimble Cityworks	CWE-502	CAPEC-586 Object Injection	KEV one day after publication; water sector	[46] [82]
CVE-2026-110936	Siemens Software Center	CWE-427	CAPEC-38, CAPEC-471 Search Order Hijacking	Exploited; KEV 2026-10-20	[44] [82]
CVE-2025-67038	Lantronix EDS3000PS and EDS5000	CWE-78 (KEV also lists CWE-94)	5 entries for CWE-78, for example CAPEC-88 OS Command Injection; CWE-94 adds 3 entries, for example CAPEC-242 Code Injection	KEV 2026-06-23; advisory still says no exploitation	[47] [40] [82]
CVE-2021-26829	OpenPLC ScadaBR	CWE-79	6 entries, for example CAPEC-63 Cross-Site Scripting (XSS)	TwoNet HMI defacement; KEV 2025-11-28	[18] [40] [82]
CVE-2021-26828	OpenPLC ScadaBR	CWE-434	CAPEC-1 Accessing Functionality Not Properly Constrained by ACLs	Honeypot webshell; KEV 2025-12-03	[18] [40] [82]
CVE-2017-7921	Hikvision	CWE-287	10 entries, for example CAPEC-115 Authentication Bypass	KEV 2026-03-05, same day as CVE-2021-22681	[40] [82]
CVE-2018-7522, CVE-2018-8872	Schneider Triconex Tricon MP 3008	CWE-119	12 entries, for example CAPEC-100 Overflow Buffers	TRITON lineage	[60] [82]
CVE-2022-42475	Fortinet FortiGate	not checked	not mapped	Volt Typhoon initial access	[6]
CVE-2018-0171	Cisco Smart Install	not checked	not mapped	FSB Center 16	[54]
CVE-2024-2617	Hitachi Energy RTU	not checked	not mapped	Secure-update bypass, not needed in Poland	[21]

CVE	Product	CWE (as the source lists it)	CAPEC the library relates to that CWE	Where it meets the record	Sources
CVE-2020-15368	ASRock AsrDrv103.sys	not checked	not mapped	INCONTROLLER lineage	[57] [58]

For the advisory-wide CWE classes of Part 2.4, the library relates CWE-306 to CAPEC-12, CAPEC-166, CAPEC-216, CAPEC-36 and CAPEC-62; CWE-307 to CAPEC-16, CAPEC-49 Password Brute Forcing (maps T1110.001), CAPEC-560, CAPEC-600 and others; CWE-125 to CAPEC-540; and CWE-787 to nothing [82] (**Confirmed**). See the CWE Reference and CAPEC Reference.

6.7 D3FEND countermeasures

The library's D3FEND data (version 1.6.0) and pages cover these countermeasures; each row gives examples of the technique ids the library maps, some of them revoked ICS ids, and "among others" marks a row that lists a subset; the linked page carries the full list [82] (**Confirmed**).

D3FEND countermeasure	Examples of techniques the library maps it to	Where it meets the record
Change Default Password (D3-CDP)	T0812 (revoked; now T1694.001), T0859, T1078.001, T1110.001 to .003, T1531 among others	Unitronics, VNC-exposed HMIs, the Polish "Default" account
Multi-factor Authentication (D3-MFA)	T0812 (revoked; now T1694.001), T0892, T1003.003, T1110.001 to .003, T1555.001 (under the study's T1555), T1558 among others	Remote access; Volt Typhoon's NTDS theft
Inbound Traffic Filtering (D3-ITF)	T0819, T0822, T0865, T1190, T1499.002 (under the study's T1499) among others	Exposed devices and edge appliances
Network Traffic Filtering (D3-NTF)	T0814, T0836, T0843, T0855 (revoked; now T1692.001), T0857 (revoked; now T1693.001), T0878, T0885, T0886, T0889, T1041 among others	PLC writes and program downloads; firmware upload paths
Message Authentication (D3-MAN)	T0801, T0806, T0809, T0836, T0838, T0843, T0855 (revoked; now T1692.001), T0857 (revoked; now T1693.001), T0878, T0885, T0889 among others	Authenticated program downloads and parameter writes
OT Variable Access Restriction (D3-OVAR)	T0801, T0806, T0809, T0836 among others	Setpoint and parameter changes
Service Binary Verification (D3-SBV)	T0843, T0845, T0889 among others	Comparing running logic to known-good
Restore Software (D3-RS)	T0839 (revoked; now T1693.002), T0843, T0845, T0889 among others	Restoring verified logic and module firmware
Restore Configuration (D3-RC)	T1037.004 among others	IOControl's RC-script persistence
System Firmware Verification (D3-SFV)	T1542.001, T1542.004 (the page's full list; Enterprise only)	Relevant to the Polish RTU firmware upload (ICS T1693.001) only by analogy (**Inferred**); the library maps no ICS id to it

See the D3FEND Reference.

6.8 Navigator layers

- ICS: `navigator/case-studies/ics-attacks-2024-2026-ics.json` (open in Navigator), domain `ics-attack`, ATT&CK version 20, the 43 techniques of Part 6.2 in 49 technique and tactic entries. Curated layers under `navigator/library-layers/` must be `enterprise-attack`, so the ICS layer lives in its own folder with an entry in the `navigator/index.md` catalog.
- Enterprise: `navigator/library-layers/ics-attacks-2024-2026-enterprise.json` (open in Navigator), domain `enterprise-attack`, the 79 techniques of Part 6.3 in 98 entries.

Each technique is shown under all its tactics, and each comment names the events and the source numbers of this study. A score of 100 means only that a cited source maps the technique to an event here, not severity or prevalence.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

Cross-cutting themes

- **The attack surface is configuration, the advisory stream is code.** Part 1 is a record of default passwords, exposed ports and native engineering tools [1] [12] [29]; Part 2 is a record of embedded operating systems and memory-safety bugs [37]. Both matter, but they call for different teams and different clocks (**Inferred**).
- **Escalation runs through the logic layer.** From erased ladder logic in 2023 [1] to disabled shutdown and alarm logic in 2026 [29] and corrupted RTU firmware in Poland [21], the target moved from what operators see to what keeps the process safe (**Inferred**).
- **Loss of view is the common impact.** AA25-343A [12], the MicroLogix incidents [31] and ATT&CK's T0829 rows across five events (Part 6.2) all land on operators losing sight of the process, which is why manual operation keeps appearing as a mitigation [90] (**Inferred**).
- **Signals arrive out of order.** Exploitation appears on honeypots [18], then in KEV [40], and sometimes never in the advisory text [47]. Teams that wait for the advisory to change are the last to know (**Inferred**).
- **Attribution is layered and sometimes contradictory, even within one government.** Z-Pentest has three framings [11] [12] [13], and Poland has three attributing sources and two Russian services [21] [22] [23]. Defenders can act on behavior while the naming settles.
- **Persona claims inflate the record in both directions.** CARR, TwoNet and Blackjack all claimed more than responders could confirm [8] [18] [61], while the events with the clearest physical effect (Lviv, US

water in July 2026) were claimed by no one in the sources opened [5] [31] (**Inferred**).

Sources

#	Source	URL	Opened	Grade
1	CISA and partners, AA23-335A, IRGC-affiliated cyber actors exploit PLCs (2023-12-01, last revised 2024-12-18)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-335a	3 Nov 2026	Confirmed
2	US Treasury, press release jy2072, IRGC-CEC officials sanctioned (2024-02-02)	https://home.treasury.gov/news/press-releases/jy2072	3 Nov 2026	Confirmed
3	Claroty Team82, "Inside a New OT/IoT Cyber Weapon: IOCONTROL" (2024-12-10)	https://claroty.com/team82/research/inside-a-new-ot-iot-cyber-weapon-iocontrol	3 Nov 2026	Confirmed
4	TechTarget, report on the Dragos FrostyGoop analysis	https://www.techtarget.com/cybersecurity/news/366596552/Dragos-New-ICS-malware-FrostyGoop-abuses-Modbus	3 Nov 2026	Reported
5	Dragos, press release on the 2025 OT/ICS Year in Review (2025-02-25)	https://www.dragos.com/resources/press-release/dragos-reports-ot-ics-cyber-threats-escalate-amid-geopolitical-conflicts-and-increasing-ransomware-attacks	3 Nov 2026	Confirmed
6	CISA, NSA and FBI, AA24-038A, PRC state-sponsored actors (2024-02-07)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-038a	3 Nov 2026	Confirmed
7	SecurityWeek, "China's Volt Typhoon Hackers Dwelled in US Electric Grid for 300 Days" (2025-03-12)	https://www.securityweek.com/chinas-volt-typhoon-hackers-dwelled-in-us-electric-grid-for-300-days/	3 Nov 2026	Reported
8	Mandiant, "APT44: Unearthing Sandworm" report PDF (April 2024)	https://services.google.com/fh/files/misc/apt44-unearthing-sandworm.pdf	3 Nov 2026	Confirmed
9	Mandiant / Google Cloud blog, APT44 announcement (2024-04-17)	https://cloud.google.com/blog/topics/threat-intelligence/apt44-unearthing-sandworm	3 Nov 2026	Confirmed
10	SecurityWeek, Kansas water facility switches to manual operations (2024-09-24)	https://www.securityweek.com/kansas-water-facility-switches-to-manual-operations-following-cyberattack/	3 Nov 2026	Reported
11	US Department of Justice, press release 25-1158 on CARR and NoName057(16) (2025-12-09, updated 2026-07-22)	https://www.justice.gov/opa/pr/justice-department-announces-actions-combat-two-russian-state-sponsored-cyber-criminal	3 Nov 2026	Confirmed
12	FBI, CISA, NSA and partners, AA25-343A, pro-Russia hacktivists and OT (2025-12-09, last revised 2025-12-18)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-343a	3 Nov 2026	Confirmed
13	AP via SecurityWeek, Denmark blames Russia for cyberattacks on a water utility (2025-12-19)	https://www.securityweek.com/denmark-blames-russia-for-cyberattacks-ahead-of-elections-and-on-water-utility/	3 Nov 2026	Reported

#	Source	URL	Opened	Grade
14	Reuters via The Star, Norway spy chief blames Russian hackers for dam sabotage (2025-08-13)	https://www.thestar.com.my/news/world/2025/08/13/norway-spy-chief-blames-russian-hackers-for-dam-sabotage-in-april	3 Nov 2026	Reported
15	BleepingComputer, pro-Russian hackers blamed for water dam sabotage in Norway (2025-08-14)	https://www.bleepingcomputer.com/news/security/pro-russian-hackers-blamed-for-water-dam-sabotage-in-norway/	3 Nov 2026	Reported
16	iLaks, citing NRK, PST drops the Bremanger case (2025-10-03)	https://ilaks.no/pro-russiske-hackere-apnet-vannkilden-til-postsmoltanlegg-na-har-pst-henlagt-saken/	3 Nov 2026	Reported
17	Reuters via Arab News, Poland foiled cyberattack on a big city's water supply (2025-08-14)	Arab News, node 2611819 (not linked: the page returned 403 to the library's link check on 3 November 2026)	3 Nov 2026	Reported
18	Forescout Vedere Labs, "Anatomy of a Hacktivist Attack" (2025-10-09)	https://www.forescout.com/blog/anatomy-of-a-hacktivist-attack-russian-aligned-group-targets-otics/	3 Nov 2026	Confirmed
19	Canadian Centre for Cyber Security, AL25-016 (2025-10-29)	https://www.cyber.gc.ca/en/alerts-advisories/al25-016-internet-accessible-industrial-control-systems-ics-abused-hacktivists	3 Nov 2026	Confirmed
20	CERT Polska, energy sector incident report post (2026-01-30)	https://cert.pl/en/posts/2026/01/incident-report-energy-sector-2025/	3 Nov 2026	Confirmed
21	CERT Polska, Energy Sector Incident Report 2025, PDF (report date January 2026)	https://cert.pl/uploads/docs/CERT_Polska_Energy_Sector_Incident_Report_2025.pdf	3 Nov 2026	Confirmed
22	ESET, DynoWiper technical analysis and attribution (2026-01-30)	https://www.welivesecurity.com/en/eset-research/dynowiper-update-technical-analysis-attribution/	3 Nov 2026	Confirmed
23	Dragos, Poland power grid attack targets distributed energy (2026-01-28)	https://www.dragos.com/blog/poland-power-grid-attack-electrum-targets-distributed-energy-2025	3 Nov 2026	Confirmed
24	The Hacker News, Poland attributes December cyberattacks (2026-01-31)	https://thehackernews.com/2026/01/poland-attributes-december-cyber.html	3 Nov 2026	Reported
25	ESET, APT Activity Report Q2 2025 to Q3 2025 (2025-11-06)	https://www.welivesecurity.com/en/eset-research/eset-apt-activity-report-q2-2025-q3-2025/	3 Nov 2026	Confirmed
26	Dragos, press release on the 2026 Year in Review (2026-02-17)	https://dragos.com/resources/press-release/dragos-2026-year-in-review-new-ot-threats-ransomware	3 Nov 2026	Confirmed
27	Dragos, blog on the 2026 OT Cybersecurity Year in Review (2026-02-17)	https://www.dragos.com/blog/dragos-2026-ot-cybersecurity-year-in-review	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
28	CISA, FBI, DC3 and NSA, fact sheet on Iranian cyber actors (2025-06-30)	https://www.cisa.gov/resources-tools/resources/iranian-cyber-actors-may-target-vulnerable-us-networks-and-entities-interest	3 Nov 2026	Confirmed
29	FBI, CISA, NSA, EPA, DOE, USCYBERCOM CNMF and Treasury, AA26-097A (2026-04-07, updated 2026-07-22)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa26-097a	3 Nov 2026	Confirmed
30	AA26-097A, PDF edition (2026-04-07)	https://www.ic3.gov/CSA/2026/260407.pdf	3 Nov 2026	Confirmed
31	FBI and EPA, PSA I-073026-PSA (2026-07-30)	https://www.ic3.gov/PSA/2026/PSA260730.pdf	3 Nov 2026	Confirmed
32	CISA, alert urging the water sector to protect OT against PLC targeting (2026-07-30)	https://www.cisa.gov/news-events/alerts/2026/07/30/cisa-urges-water-and-wastewater-systems-sector-protect-ot-against-activity-targeting-plcs	3 Nov 2026	Confirmed
33	BleepingComputer, CISA warns of cyberattacks disrupting US water utilities (2026-07-31)	https://www.bleepingcomputer.com/news/security/cisa-warns-of-cyberattacks-disrupting-us-water-utilities/	3 Nov 2026	Reported
34	Jaguar Land Rover, statement on cyber incident (2025-09-02)	https://media.jlr.com/corporate/news/2025/09/statement-cyber-incident	3 Nov 2026	Confirmed
35	TechCrunch, Asahi stops production after cyberattack (2025-09-30)	https://techcrunch.com/2025/09/30/japans-beer-making-giant-asahi-stops-production-after-cyberattack/	3 Nov 2026	Reported
36	CISA, ICS advisories listing	https://www.cisa.gov/news-events/ics-advisories	3 Nov 2026	Confirmed
37	CISA CSAF repository, `csaf_files/OT/white/2024` to `2026` (develop, commit 90e44dd), including `icsa-26-295-11.json`; counts computed for this study	https://github.com/cisagov/CSAF	3 Nov 2026	Confirmed
38	Team Star Wolf Intelligence Hub data: `data/v7/history/2024.json` to `2026.json` (later on 3 November 2026 split into half-year part files such as `history/2026-h2.json`, from which the Part 2.7 row counts reproduce), `data/v7/kev/2026.json`, `data/v7/index.json`	https://teamstarwolf.github.io/intelligence-hub/data/v7/history/2026-h2.json	3 Nov 2026	Confirmed
39	Siemens ProductCERT CSAF feed (updated 2026-11-03)	https://cert-portal.siemens.com/productcert/csaf/ssa-feed-tlp-white.json	3 Nov 2026	Confirmed
40	CISA Known Exploited Vulnerabilities catalog, JSON feed, catalogVersion 2026.11.03	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	3 Nov 2026	Confirmed
41	CISA Known Exploited Vulnerabilities catalog page	https://www.cisa.gov/known-exploited-vulnerabilities-catalog	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
42	NVD CVE API 2.0 records for CVE-2021-22681, CVE-2023-6448, CVE-2025-0994, CVE-2026-110936, CVE-2025-20352, CVE-2025-1316, CVE-2024-8956, CVE-2024-8957, CVE-2025-32433, CVE-2025-67038, CVE-2024-54085, CVE-2021-26829, CVE-2021-26828, CVE-2019-7256 and CVE-2017-7921 (same endpoint, one `cveId` each)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2021-22681	3 Nov 2026	Confirmed
43	CISA, ICSA-21-056-03, Rockwell Logix controllers (Update A, 2021-03-18)	https://www.cisa.gov/news-events/ics-advisories/icsa-21-056-03	3 Nov 2026	Confirmed
44	Siemens ProductCERT, SSA-580366, Siemens Software Center (2026-10-15, V1.2 2026-10-19)	https://cert-portal.siemens.com/productcert/html/ssa-580366.html	3 Nov 2026	Confirmed
45	CISA, ICSA-26-295-03, Siemens Software Center (2026-10-22)	https://www.cisa.gov/news-events/ics-advisories/icsa-26-295-03	3 Nov 2026	Confirmed
46	CISA, ICSA-25-037-04, Trimble Cityworks (2025-02-06, Update A 2025-02-11)	https://www.cisa.gov/news-events/ics-advisories/icsa-25-037-04	3 Nov 2026	Confirmed
47	CISA, ICSA-26-069-02, Lantronix EDS3000PS and EDS5000 (Update B, 2026-10-08)	https://www.cisa.gov/news-events/ics-advisories/icsa-26-069-02	3 Nov 2026	Confirmed
48	CISA, Stakeholder-Specific Vulnerability Categorization page	https://www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc	3 Nov 2026	Confirmed
49	CISA Vulnrichment README	https://raw.githubusercontent.com/cisagov/vulnrichment/develop/README.md	3 Nov 2026	Confirmed
50	CISA Vulnrichment record, CVE-2021-22681	https://raw.githubusercontent.com/cisagov/vulnrichment/develop/2021/22xxx/CVE-2021-22681.json	3 Nov 2026	Confirmed
51	CISA Vulnrichment record, CVE-2025-41660 (CODESYS)	https://github.com/cisagov/vulnrichment/blob/develop/2025/41xxx/CVE-2025-41660.json	3 Nov 2026	Confirmed
52	Moxa, security advisory page	https://www.moxa.com/en/support/product-support/security-advisory	3 Nov 2026	Confirmed
53	Mitsubishi Electric PSIRT RSS feed (feed date 2026-10-15)	https://www.mitsubishielectric.com/psirt/vulnerability/xml/info.xml	3 Nov 2026	Confirmed
54	FBI, PSA I-082025-PSA on FSB Center 16 (2025-08-20)	https://www.ic3.gov/PSA/2025/PSA250820	3 Nov 2026	Confirmed
55	Mandiant, "Sandworm Disrupts Power in Ukraine Using a Novel Attack Against Operational Technology" (2023-11-09)	https://cloud.google.com/blog/topics/threat-intelligence/sandworm-disrupts-power-ukraine-operational-technology	3 Nov 2026	Confirmed
56	Dragos, CHERNOVITE's PIPEDREAM (2022-04-13)	https://www.dragos.com/blog/chernovite-pipedream-malware-targeting-industrial-control-systems	3 Nov 2026	Confirmed
57	Mandiant, INCONTROLLER state-sponsored ICS tooling (2022-04-13)	https://cloud.google.com/blog/topics/threat-intelligence/incontroller-state-sponsored-ics-tool	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
58	DOE, CISA, NSA and FBI, AA22-103A (2022-04-13)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-103a	3 Nov 2026	Confirmed
59	US Treasury, press release sm1162, TsNIIKhM designated (2020-10-23)	https://home.treasury.gov/news/press-releases/sm1162	3 Nov 2026	Confirmed
60	CISA, ICSA-18-107-02, Schneider Electric Triconex Tricon (Update B, 2018-12-18)	https://www.cisa.gov/news-events/ics-advisories/icsa-18-107-02	3 Nov 2026	Confirmed
61	Claroty Team82, "Unpacking the Blackjack Group's Fuxnet Malware" (2024-04-12, updated 2024-04-15)	https://claroty.com/team82/research/unpacking-the-blackjack-groups-fuxnet-malware	3 Nov 2026	Confirmed
62	Caltagirone, Pendergast and Betz, "The Diamond Model of Intrusion Analysis" (2013)	https://www.activeresponse.org/wp-content/uploads/2013/07/diamond.pdf	3 Nov 2026	Confirmed
63	Dragos, "Uncovering ICS Threat Groups" webinar summary (2019-01-30)	https://www.dragos.com/blog/webinar-summary-uncovering-ics-threat-activity-groups/	3 Nov 2026	Confirmed
64	Dragos, BAUXITE threat group profile	https://www.dragos.com/threat/bauxite/	3 Nov 2026	Confirmed
65	Mandiant, "DebUNCing Attribution: How Mandiant Tracks Uncategorized Threat Actors" (2020-12-17)	https://cloud.google.com/blog/topics/threat-intelligence/how-mandiant-tracks-uncategorized-threat-actors	3 Nov 2026	Confirmed
66	Mandiant, GRU and its Telegram personas (2022-09-23, updated April 2024)	https://cloud.google.com/blog/topics/threat-intelligence/gru-rise-telegram-minions/	3 Nov 2026	Confirmed
67	US Treasury, press release jy2473, CARR members sanctioned (2024-07-19)	https://home.treasury.gov/news/press-releases/jy2473	3 Nov 2026	Confirmed
68	Microsoft Learn, threat actor naming (page dated 2026-10-21)	https://learn.microsoft.com/en-us/unified-secops/microsoft-threat-actor-naming	3 Nov 2026	Confirmed
69	Kaspersky, "OlympicDestroyer is here to trick the industry" (2018-03-08)	https://securelist.com/olympicdestroyer-is-here-to-trick-the-industry/84295/	3 Nov 2026	Confirmed
70	MITRE ATT&CK, group G1027 CyberAv3ngers (v1.1, modified 2026-10-07)	https://attack.mitre.org/groups/G1027/	3 Nov 2026	Confirmed
71	MITRE ATT&CK, campaign C0031 Unitronics Defacement Campaign	https://attack.mitre.org/campaigns/C0031/	3 Nov 2026	Confirmed
72	MITRE ATT&CK, campaign C0041 FrostyGoop Incident and software S1165 FrostyGoop	https://attack.mitre.org/campaigns/C0041/	3 Nov 2026	Confirmed
73	MITRE ATT&CK, software S1045 INCONTROLLER	https://attack.mitre.org/software/S1045/	3 Nov 2026	Confirmed
74	MITRE ATT&CK, software S1072 Industroyer2 and S0604 Industroyer	https://attack.mitre.org/software/S1072/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
75	MITRE ATT&CK, software S9046 IOControl (created 2026-09-02)	https://attack.mitre.org/software/S9046/	3 Nov 2026	Confirmed
76	MITRE ATT&CK, software S1157 Fuxnet	https://attack.mitre.org/software/S1157/	3 Nov 2026	Confirmed
77	MITRE ATT&CK, group G0034 Sandworm Team (v4.2)	https://attack.mitre.org/groups/G0034/	3 Nov 2026	Confirmed
78	MITRE ATT&CK, group G1017 Volt Typhoon (v2.0)	https://attack.mitre.org/groups/G1017/	3 Nov 2026	Confirmed
79	MITRE ATT&CK, campaign C0063 2025 Poland Wiper Attacks	https://attack.mitre.org/campaigns/C0063/	3 Nov 2026	Confirmed
80	MITRE ATT&CK for ICS, mitigation M0930 Network Segmentation (v1.1)	https://attack.mitre.org/mitigations/M0930/	3 Nov 2026	Confirmed
81	MITRE ATT&CK for ICS, technique T0892 Change Credential	https://attack.mitre.org/techniques/T0892/	3 Nov 2026	Confirmed
82	TeamStarWolf library data and pages on main `e85b559`: `data/attack/superseded_by.jsonl`, `data/attack/ics/technique_profiles.jsonl`, `data/attack/ics/group_to_technique.jsonl`, `data/attack/ics/mitigations.jsonl`, `data/attack/technique_profiles.jsonl`, `data/attack/campaign_profiles.jsonl`, `data/attack/group_profiles.jsonl`, `data/attack/d3fend_countermeasures.jsonl`, `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl`, the `mitre/` tree, `THREAT_ACTORS.md`, `MALWARE_FAMILIES.md`, `NOTABLE_INCIDENTS.md`	https://github.com/TeamStarWolf/TeamStarWolf	3 Nov 2026	Confirmed
83	Censys, global ICS exposures in the 2024 State of the Internet report (2024-11-26)	https://censys.com/blog/global-ics-exposures-what-our-2024-state-of-the-internet-report-reveals-about-critical-infrastructure-security/	3 Nov 2026	Confirmed
84	SANS Internet Storm Center, diary 30860 (2024-04-22)	https://isc.sans.edu/diary/30860	3 Nov 2026	Confirmed
85	Palo Alto Networks Unit 42, FrostyGoop malware analysis (2024-11-19)	https://unit42.paloaltonetworks.com/frostygoop-malware-analysis/	3 Nov 2026	Confirmed
86	Censys, "Who's Knocking on Your PLC?" ICS honeypot (2026-01-15)	https://censys.com/blog/whos-knocking-on-your-plc-ics-ot-protocols-honeypot/	3 Nov 2026	Confirmed
87	CISA and partners, Foundations for OT Cybersecurity: Asset Inventory Guidance (2025-08-13)	https://www.cisa.gov/resources-tools/resources/foundations-ot-cybersecurity-asset-inventory-guidance-owners-and-operators	3 Nov 2026	Confirmed
88	NIST SP 800-82r3, Guide to Operational Technology Security (September 2023)	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r3.pdf	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
89	US EPA, enforcement alert on drinking water system cybersecurity (May 2024)	https://www.epa.gov/enforcement/enforcement-alert-drinking-water-systems-address-cybersecurity-vulnerabilities	3 Nov 2026	Confirmed
90	CISA, FBI, EPA and DOE, Primary Mitigations to Reduce Cyber Threats to OT (2025-05-06)	https://www.cisa.gov/resources-tools/resources/primary-mitigations-reduce-cyber-threats-operational-technology	3 Nov 2026	Confirmed
91	UK NCSC, "Designing safer links: secure connectivity for OT" (2026-01-14)	https://www.ncsc.gov.uk/blog-post/designing-safer-links-secure-connectivity-for-ot	3 Nov 2026	Confirmed
92	CISA, SSVC Guide (November 2022)	https://www.cisa.gov/sites/default/files/publications/cisa-ssvc-guide%20508c.pdf	3 Nov 2026	Confirmed
93	CISA, BOD 26-04, Prioritizing Security Updates Based on Risk (2026-06-10)	https://www.cisa.gov/news-events/directives/bod-26-04-prioritizing-security-updates-based-risk	3 Nov 2026	Confirmed
94	Claroty, State of CPS Security 2025: OT exposures (2025-02-04)	https://blog.claroty.com/blog/claroty-s-state-of-cps-security-2025-ot-exposures	3 Nov 2026	Confirmed
95	Nozomi Networks Labs, OT/IoT Security Report, February 2026 (second half of 2025)	https://www.nozominetworks.com/resources/ot-iot-security-report-february-2026	3 Nov 2026	Confirmed
96	Suricata documentation, rules (Modbus, DNP3 and ENIP/CIP keyword pages)	https://docs.suricata.io/en/latest/rules/index.html	3 Nov 2026	Confirmed
97	Wazuh documentation, proof-of-concept guide: network IDS integration with Suricata	https://documentation.wazuh.com/current/proof-of-concept-guide/integrate-network-ids-suricata.html	3 Nov 2026	Confirmed
98	Siemens ProductCERT homepage	https://productcert.siemens.com/	3 Nov 2026	Confirmed
99	CERT@VDE, advisories	https://certvde.com/en/advisories/	3 Nov 2026	Confirmed

Not opened, so not cited as sources: the Dragos FrostyGoop report and the Dragos Littleton case study (relayed by [4] and [7]); the DDIS, PST and NRK originals (relayed by [13], [14] and [16]); Minnesota IT Services' own statement (relayed by [33]); the city notice from Arkansas City (relayed by [10]); and the Dragos 2026 Year in Review report PDF (its press release and blog were opened as [26] and [27]).

Related references

- ICS/OT Security Reference, the ICS ATT&CK Technique Atlas and the ICS, OT and hardware hub
- Threat Actors
- Malware Families
- Notable Incidents

- CVE Reference
- ATT&CK Software Reference
- MITRE pages: G0034 Sandworm Team, G1017 Volt Typhoon, G0035 Dragonfly, G0088 TEMP.Veles, S9046 IOControl, S9038 DynoWiper, S9039 LazyWiper, S1072 Industroyer2, S0604 Industroyer, C0041, C0063, C0025, C0028, C0034, C0030, C0035, C0039, and the technique pages linked in Part 6.3
- CWE Reference, CAPEC Reference, D3FEND Reference
- The Team Star Wolf Intelligence Hub for the live KEV and ICS advisory ledgers
- All case studies